ARCHITECTURE RESEARCH · V2 · OCTOBER 2026

# Vault

A computer that only its owner, and the successors they name, can use. Not a login gate: an always-on loop of several channels at once that keeps proving a living human is at the keyboard, which human it is, and that every input comes from them. For everyday laptops and desktops, and for the terminals that guard frontier AI models.

**Prepared by** Pablo Peniche **Status** Draft for discussion · not for distribution **Sources** 279, numbered inline

**Supersedes** v1, the gate-based design (PDF)

BOTTOM LINE

## Prove the owner behind every input.

Vault should be built as a closed verification loop whose output is not a session but authority to act, re-earned every few seconds and attributed to each input, and held only while one invariant is true: everything reaching the protected context is explained by a single attested, living body, that body is the enrolled owner or a successor the owner named, and no channel contradicts it. Actions by the owner's AI agents travel on a separate, owner-signed track. Nothing found on the market does this. Consumer platforms verify a paired token's proximity, its custody since the last unlock, or identity only at risky moments, and frontier labs verify tokens and second approvers[1, 2, 3, 4, 5]. The evidence supports a loop with five parts. On-body carriers prove liveness and keep custody. Attested device-side sensors supply identity. Ambient sensors report presence. Cross-checks run by the trusted channel bind these sources together. A trust engine lets every live channel veto but no channel vouch alone. The loop is enforced outside the general-purpose operating system: by a secure-element hub on consumer machines, and by a secretless terminal feeding a confidential-computing keyserver at AI labs. The founder's two instincts survive in modified form. "All channels must be on" fails as a check-by-check AND, because five channels that each falsely reject 1% of the time, checked every 10 seconds, would falsely fail about 141 times in an 8-hour day (this report's arithmetic, Section 7). It works as "every proposition is covered at every moment and any channel can veto". "A blood sample" cannot identify anyone continuously, but a single-use microneedle sensor is the strongest custody seal available[6, 7]. The loop cannot see coercion, so duress and succession remain ceremonies. And proof that an input came from a human hand, not an agent or an injected device, is the least mature link on both tiers.

*Labelling conventions used throughout: "vendor claim" marks a figure published by a vendor and not independently evaluated; "secondary" marks press, aggregator or search-summary coverage that was not checked against the primary source; "proposal" and "inference" mark design reasoning produced by this research rather than established fact.*

# Verification becomes a loop that leases authority per input

A gate asks one question at the door, "may this person begin?", and then trusts whatever happens inside. Keeping the gate open with periodic presence attestations improves it but does not change the question being answered. Each attestation says that an enrolled face is still in front of the camera. It says nothing about whether the keystrokes now arriving came from that person's hands, from the person's AI agent, from malware riding the session, or from a cable that pretends to be a keyboard. It says nothing either about whether the person in the chair is acting freely. At least four of the threats analyzed in Section 2 (AI agents, injected input, piggybacked malware and coercion) can operate while a legitimate owner sits verified at the machine. A presence-kept gate passes all four by construction.

The thesis of this report is that Vault must instead be a **control loop**. In a loop, verification is a continuously evaluated invariant, and authority is a quantity the system modulates moment by moment, not a state it grants once. The loop continuously tests four propositions. The first is that a **living human body is present and attached** to the machine's sensors. The second is that this body is **the enrolled person**. The third is that **the inputs come from that body** and not from an agent, malware or injected device. The fourth, tested separately because nothing can measure it directly, is that **the person is acting freely**. Channels on the body, on the device and in the room produce evidence. Cross-checks bind that evidence to one body. A trust engine turns it into a running estimate that the invariant holds. An enforcement point outside the operating system converts the estimate into keys, input routing and capability, epoch by epoch. When custody breaks, the loop does not reopen a door; it schedules its own re-anchoring check. When channels contradict each other, authority ends at once. The owner's agents are separate principals with their own identity and owner-signed scope.

Eight findings support the thesis:

---

01 **No shipping platform verifies identity continuously in hardware; each verifies something weaker.** Apple Watch unlock verifies custody of a token since the last real unlock within 2–3 m. Android Extend Unlock caps unlocked time at 4 hours, and its on-body mode cannot tell who carries the phone. Apple Stolen Device Protection and Android Identity Check re-verify identity only at risky moments. Nymi authenticates once per shift and carries trust on on-body detection (vendor claim)[1, 2, 3, 8, 9]. Lab frameworks commit to MFA, hardware keys and two-party approval, not to a continuously verified human[4, 5, 10]. Enterprise agents that run periodic face or behavioural checks exist, but as endpoint software without published liveness or injection defences (vendor claims)[11, 12]. Vault would be the first consumer product to attempt continuous identity, and the first found anywhere to root it in hardware (inference from this search).

---

02 **The channels split the work unevenly: liveness is cheap, identity is scarce, custody is negative evidence, and input provenance barely exists.** Pulse, radar and interstitial-fluid sensors readily show a living body. Identity is reliable only from a few hard biometrics on attested paths. Wrist PPG identification collapsed to a Matthews correlation coefficient (MCC) of 0.07–0.08 when trained on one half of a semester and tested on the other[13], and the Nymi Band's ECG check was spoofed 81% of the time[14]. Custody always means "no break was detected", never positive proof. No shipping keyboard signs ordinary keystrokes[15].

03 **Agreement between channels binds them to one body but never identifies that body.** Real-time face swaps carry the pulse of the person driving them, with r = 0.89 for DeepFaceLive[16]. Tools exist to insert a chosen pulse into video[17]. Wrist-to-keyboard correlation (ZEBRA) was evaded about 40% of the time, because the attacker's own input decided when comparisons happened[18, 19]. Identity must enter through a hard biometric on an attested path and then be carried by custody, and the trusted channel must drive every comparison.

04 **"All channels must be on" fails as a per-check AND and works as universal veto plus role coverage.** Five channels at a 1% false-reject rate fail 4.9% of checks together. Daugman shows that combining a weak test with a strong one by AND at their crossover points can be 5.5 times worse than the strong test alone[20]. Requiring three consecutive failures cuts the 141 daily false lockouts to about 0.34 at 30 seconds of added latency for *missing* evidence. Treating *contradictions* as instant vetoes keeps impostor detection immediate (inference from the arithmetic in Section 7).

05 **A blood sample cannot identify anyone continuously, but a microneedle sensor is the best custody seal available.** Rapid DNA takes about 90 minutes, and DNA is shed everywhere[6, 21]. Metabolic profiles uniquely re-identify only about 40% of people after seven years and need laboratory instruments[22]. A single-use microneedle sensor that "cannot be re-applied" once it falls off[7] and streams live interstitial chemistry for 5–15 days is harder to transfer than any clasp. That holds only if it is applied during a strong identity ceremony, and no glucose-sensor maker documents a security-grade removal event today[23].

06 **The AI-agent question is answered by attribution, not detection.** Operating-system injection flags only describe which software path an event took. A kernel virtual-HID driver or a malicious USB cable looks like a keyboard[24, 25], and desktop agents use the same permission as malware[26, 27]. The loop should attribute each input to the present owner, to the owner's agent (a distinct account holding an owner-signed mandate), or to nobody, in which case it is blocked. It should then confirm consequential agent actions through a channel the agent cannot press[28, 29, 30].

07 **Enforcement has to sit outside the general-purpose OS on both tiers.** Security tools were disabled in about 48% of 2024 intrusions[31], and a local administrator could inject Windows Hello face templates[32]. For labs, the secretless terminal and confidential-computing keyserver remain the enforcement point, now fed signed loop state instead of presence heartbeats[33, 34]. The consumer equivalent this report proposes is a small hub with a secure element that terminates the wearable links, sits inline between keyboard and computer, and holds the vault keys. The add-on sensor kit costs roughly $640–$1,400, often on top of hardware buyers already own (inference from listed prices).

08 **The loop cannot see coercion, so duress and succession stay ceremonies.** Stress inference fails statistically, and for EU employees it is presumptively prohibited[35, 36, 37]. Explicit covert signals, silent degradation, quorum and delay remain the answer[38, 39, 40]. The loop helps in two narrow ways: it offers more covert signalling surfaces, and its owner-liveness signal can hold the heir path closed. The stakes are rising. Verified crypto "wrench attacks" hit a record 72 in 2025[41], and a computer bound to one body makes that body the attack surface.

The two tiers share one architecture and differ in enforcement, law and buyers. A consumer Vault runs on commodity laptops and desktops, faces US consumer health-data law (Washington's My Health My Data Act counts keystroke rhythms and vital signs)[42], and sells to high-risk individuals through custody, executive-protection and family-office channels. An AI-lab Vault runs on dedicated terminals, faces the EU AI Act's workplace emotion-recognition ban and employment biometric law, and sells to an estimated 5–12 frontier developers plus their infrastructure partners (an inference built on Epoch AI's count of 12 developers with models above 10^25 FLOP)[43]. Sections 8, 11 and 12 treat both tiers side by side.

# The dangerous moments come after the check

A gate verifies at an event and then trusts a session. Even a gate that renews itself every few seconds with a signed "enrolled face present" attestation answers a narrow question: whether the right person is nearby. The threat record shows that the costly failures happen inside the session, through paths that this question never covers.

## Handover after login is the oldest gap and the shipping precedents leave it open

Every consumer continuity feature leaves a window in which someone else can take over an unlocked machine. Android's on-body detection may take "up to one minute" to lock after a phone is set down, and "5-10 minutes" after the owner gets into a vehicle. Its trusted-device mode lets anyone near a paired Bluetooth device keep the phone unlocked, and Google itself warns that a Bluetooth connection can be imitated[2]. Reviewers measured 15–20 seconds to relock, and a 2019 bug left phones unlocked for minutes on a still table[44, 45]. Windows Dynamic Lock locks "within about a minute" of the paired phone leaving range, and never unlocks[46]. Windows presence sensing spaces locks at least 15 seconds apart to prevent flapping[47]. Apple requires the Mac to have been unlocked by another method after the Watch was put on, and limits watch-based iPhone unlock to 6.5 hours since a real unlock[1]. Enterprise systems are slower still. Microsoft Entra's continuous access evaluation propagates revocation in "up to 15 minutes" with session tokens valid for up to 28 hours[48]. NIST SP 800-63B-4 caps the highest assurance sessions at 12 hours and does not describe continuous biometric authentication at all[49].

These windows matter because the people best placed to exploit them are close. In a SOUPS 2016 study, an estimated 20% of US adults had looked through someone else's phone in the past year[50]. On the lab side, coverage of the Linwei Ding indictment reported an allegation that a colleague scanned Ding's badge while he was abroad[51]. Ding was convicted in January 2026 of economic espionage and theft of AI trade secrets[52]. A presence heartbeat narrows the handover window to its renewal interval, but it reports only that *a* matching face is visible. It cannot tell whether the hands on the keyboard belong to that face.

## AI agents now operate computers from inside the owner's session

Computer-use agents have moved onto the owner's real desktop. Anthropic's Claude Code computer use "runs on your actual desktop with access to the apps you approve". It needs the macOS Accessibility permission, which "lets Claude click, type, and scroll"[26]. Microsoft's Copilot Actions is "an AI agent that completes tasks for you by interacting with your apps and files ... to click, type, and scroll like a human would". Microsoft names cross-prompt injection, which can cause "data exfiltration or malware installation", as a new risk[27]. OpenAI's Operator and Google's Gemini computer-use model act mainly from browsers the vendors run[53, 54]. CAPTCHAs no longer separate these agents from people: an ETH Zurich team solved 100% of reCAPTCHAv2 challenges with off-the-shelf vision models[55].

This changes what a gate can promise. An owner who launches an agent and then sits at the desk passes every presence check, while the agent, or a prompt-injected agent, or a remote-access trojan using the same synthetic-input permission, acts with the owner's full authority. Not-a-Bot, the best-known research system for attesting human input, states the structural limit plainly. Attesting that real input occurred recently "does not prevent bots from piggybacking on human activity"; it only caps their rate[56].

## Injected input looks like hardware

Operating systems can flag input injected through their user-mode APIs. Windows marks hooked keystrokes with `LLKHF_INJECTED`, and macOS gates synthetic events behind a separate PostEvent permission[57, 58]. These flags describe a software path, not a human. Since Windows 10, a kernel-mode "HID source driver" can create virtual devices whose reports the HID class driver enumerates "similar to how it enumerates those collections for a real HID device", and the driver sets its own vendor ID, product ID and container ID[24]. The O.MG Cable is sold as a USB cable with a "WiFi implant inside", offering keystroke injection and a hardware keylogger (vendor claim)[25]. The Rubber Ducky is reported to type up to about 890 characters per second with randomized jitter to evade detection (secondary)[59]. Even protected prompts have fallen. Patrick Wardle showed that macOS once converted a synthetic mouse event into one with source PID 0, which security prompts then accepted as trusted[60]. On Windows, the Secure Attention Sequence itself can be generated in software when policy allows[61].

## Real-time deepfakes and camera injection defeat face presence on an unattested path

Injection, not masks, is the dominant attack on camera biometrics. iProov's threat report counts native virtual-camera attacks up 2,665% in 2024 (vendor data)[62]. CyberArk unlocked Windows Hello by feeding a single valid infrared frame from a custom USB device (CVE-2021-34466)[63]. Researchers earlier fooled it with printed near-infrared photos, even with enhanced anti-spoofing enabled[64]. At Black Hat 2025, ERNW showed that a local administrator could insert face data into the Windows Hello database so that any face unlocked the PC. The hypervisor-isolated Enhanced Sign-in Security (ESS) mode blocks that attack[32]. Pulse-based liveness no longer separates real faces from synthetic ones. Real-time face swaps inherit the driving person's heartbeat, so a deepfake shows a plausible pulse[16]. The financial stakes are concrete. Engineering firm Arup reportedly lost about US$25 million after an employee joined a video call in which every colleague was synthetic (secondary)[65].

## Relay attacks turn proximity into distance

NCC Group demonstrated a link-layer relay attack on Bluetooth Low Energy in 2022. It convinced devices that a key was nearby "from hundreds of miles away", defeated encryption and latency checks, and affected phones, laptops, smart locks and cars[66]. Google warns that "location signals can be copied or manipulated"[2]. Apple's Auto Unlock uses peer-to-peer Wi-Fi time-of-flight ranging rather than signal strength. A 2017 TU Darmstadt thesis nevertheless reported a man-in-the-middle attack on it, and the thesis page does not say whether Apple fixed the issue[1, 67]. A gate that infers presence from radio proximity inherits all of this.

## Administrator compromise removes any enforcement that lives on the endpoint

SentinelOne's incident data show security tools disabled in about 48% of 2024 intrusions, and "EDR killers" are now bundled into ransomware-as-a-service[31]. Any verification agent that runs as ordinary software on a commodity OS shares a privilege domain with the attacker it is meant to stop. It can be killed, fed injected frames, or have its template store edited[32].

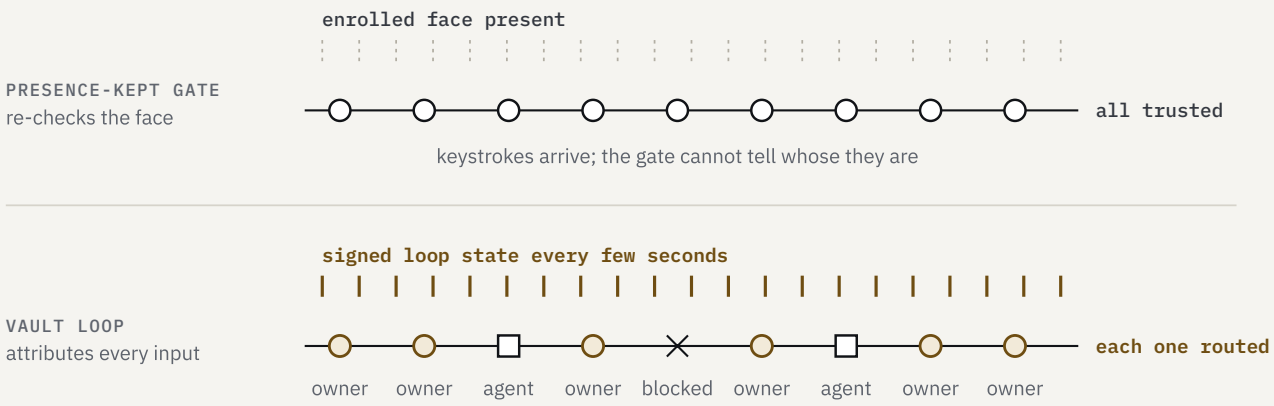
## Coercion succeeds against any loop as well as any gate

RAND's weight-security framework scores "extortion" at 4 of 5 (a 60–80% chance of success) for organized-crime and standard state attackers. It notes that "leverage can also be applied to friends and family of the target", and its only top-tier countermeasure is protecting staff physically[68]. Consumer coercion is now measurable. CertiK counted 72 verified crypto wrench attacks in 2025, up 75%, with more than $40.9 million in confirmed losses. Its early-2026 count was running 41% ahead, with victims' family members increasingly targeted[41, 69]. Jameson Lopp's catalogue of about 225 verified attacks finds about 66% succeed, and nearly a quarter are home invasions (secondary)[70]. Coercion is the one threat that defeats the loop as completely as the gate. A coerced owner is a living, enrolled body producing genuine input. Section 9 explains why the answer is procedural.

## The threat matrix: five of eight threats run with the owner present

| THREAT | CONSUMER INSTANCE | LAB INSTANCE | WHY A PRESENCE-KEPT GATE PASSES IT | WHAT THE LOOP MUST ESTABLISH (INFERENCE) |
|---|---|---|---|---|
| **Handover after login** | Family member or thief at an unlocked laptop during the relock window[2, 50] | Badge or session lent to a colleague (alleged in the Ding case)[51] | Presence is renewed by any matching face or nearby token; hands are never checked | P2 carried by custody plus P3 per input; a contradiction ends authority at once |
| **AI agent acting in the owner's session** | Desktop agent or prompt-injected agent driving apps[26, 27] | Coding or operations agent with access to weight infrastructure | Owner is present and verified while the agent types | P3 with three-way attribution; agents as separate principals |
| **Malware piggybacking on real activity** | Remote-access trojan using the PostEvent or SendInput path | Same, after endpoint compromise | Recent genuine input does not prove origin[56] | Per-event binding of each input to the body |
| **Injected HID device** | O.MG cable, Rubber Ducky[25, 59] | Same, or kernel virtual-HID driver[24] | The OS sees "hardware" | Attested input path; unknown devices cannot carry P3 |
| **Real-time deepfake or camera injection** | Virtual camera feeding the owner's face[62] | IR-frame injection[63] | Face presence on an unattested path is forgeable | Attested camera path; cross-check with on-body channels the attacker does not hold |
| **Proximity relay** | BLE relay of the owner's watch[66] | Same, for badge or band | Proximity is inferred from radio presence | Secure ranging plus custody; radio presence never counts as identity |
| **OS or administrator compromise** | Infostealer with admin rights | EDR killer, template injection[31, 32] | Enforcement lives on the compromised endpoint | Enforcement point outside the OS; fail closed on missing loop state |
| **Coercion** | Wrench attack at home[41] | Extortion of operator or family[68] | Everything is genuine | P4 cannot be measured: covert signal, quorum, delay, silent degradation |

Five of these eight threats can proceed while the verified owner is present. That is the core reason the proposition "an enrolled person is here" is the wrong thing to keep alive. The loop has to prove that the inputs are the owner's, and it has to be designed so that an owner who is present but not free cannot deliver the payoff alone.




**Gate vs. loop: the question kept alive.** A gate that re-checks "is the enrolled face still here?" trusts every keystroke inside the session alike: the owner's, an AI agent's, or an injected device's. The loop asks a question per input instead. Body-bound owner input reaches the vaulted context. Agent input goes to the agent's own workspace under an owner-signed mandate. Unattributed input is blocked and counted as a contradiction[24, 26, 56].

# What the loop must prove, and the shape of the machine that proves it

## Four propositions, three of them measurable

The loop's invariant breaks into four propositions with very different evidence behind them. The table states what each one asks, which evidence can establish it, and what the loop does when it fails. The responses are this report's proposals.

| PROPOSITION | QUESTION | EVIDENCE THAT CAN ESTABLISH IT | EVIDENCE THAT CANNOT | RESPONSE WHEN IT FAILS (PROPOSAL) |
|---|---|---|---|---|
| **P1: a living body is present and attached** | Is there a living human, and is it the one wearing the loop's sensors? | Contact pulse (ECG, PPG), interstitial chemistry, EMG, radar breathing, coherent cross-sensor timing[7, 71] | Implants, which prove possession of a key but not life (inference)[72]; any single periodic signal, which can be replayed[73] | Missing evidence: decay trust and re-anchor. Contradiction: end authority |
| **P2: it is the enrolled person** | Is this body the owner (or a named successor)? | Hard biometric on an attested path at anchor events (IR face under ESS, Touch ID, iris), carried forward by unbroken custody[15, 74, 75] | Pulse agreement, behaviour alone, possession of a token | A new or mismatched face ends authority at once; a custody break forces re-identification |
| **P3: the inputs come from that body** | Was this keystroke, click or command produced by the attested body? | Attested input path plus per-event body binding (EMG or wrist motion preceding each input)[76, 77] | Operating-system injection flags against an administrator[24]; window-level correlation[18] | Unattributed input is blocked; agent input is routed to the agent principal |
| **P4: the person is acting freely** | Is the owner coerced? | Only an explicit covert signal chosen by the owner[38] | Stress physiology, voice stress, micro-expressions[35, 78] | Never inferred; designed around with quorum, delay and indistinguishable degradation |

The first three propositions are measurable, though at very different maturity. The fourth is not, and the National Academies' review of the polygraph is a durable warning against pretending otherwise. It found no alternative physiological or behavioural method that "has yet been shown to outperform the polygraph", and judged polygraph screening "an unacceptable choice" for employee security screening[78]. The loop therefore treats freedom as a design constraint, not a measurement. It never claims to detect coercion. It makes coercion unprofitable and gives the owner a covert way to say it is happening.

## The architecture: channels, cross-checks, a trust engine and an enforcement point

The loop has four functional layers and one recurring ceremony (proposal, assembled from the evidence in Sections 4–8).

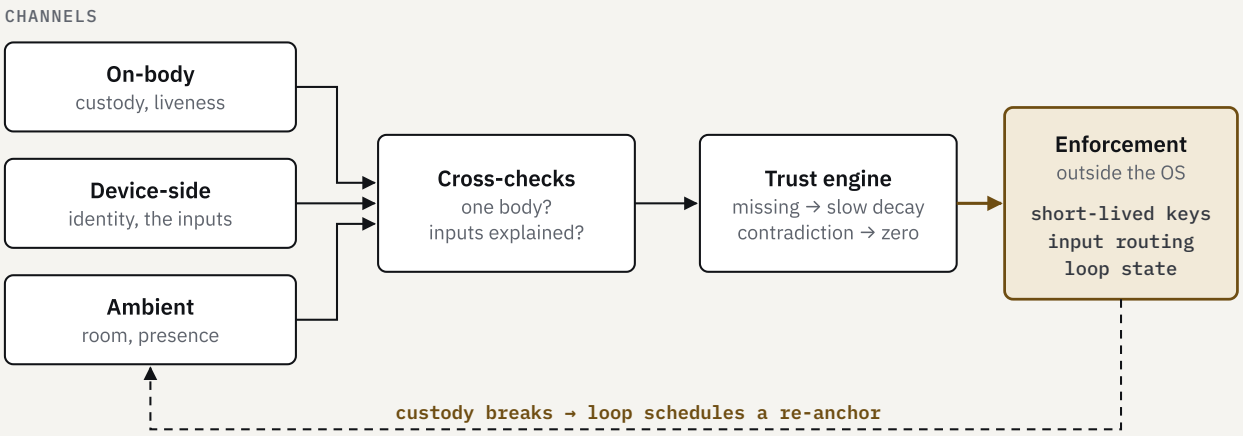
**Channels** produce raw evidence from three places. On-body carriers include a wristband, ring, patch, microneedle sensor or earbud, which provide liveness and custody and sometimes a weak identity signal. Device-side sensors include an attested IR camera, a fingerprint sensor in the keyboard and the input devices themselves, which provide identity and input events. Ambient sensors include radar presence, the webcam's pulse signal and second-person detection, which report the room. Every channel must authenticate its own output to the enforcement point, following the Magic Keyboard pattern. In that pattern the sensor holds an attestation key, pairs to the host's secure element through authenticated key exchange, and encrypts its traffic, so the host knows a reading came from a genuine sensor[15].

**Cross-checks** compare channels against each other. The same heartbeat should appear at the wrist, in the face video and in the radar return, with physiologically fixed delays. Each keystroke should be preceded by matching wrist motion or muscle activity. The wrist should stop typing when the keyboard stops. The design rules for these checks come from the attacks on earlier systems and are set out in Section 5.

**The trust engine** fuses evidence over time into a running estimate that the invariant holds. It distinguishes *missing* evidence, which decays trust slowly toward a floor, from *contradictory* evidence, which cuts trust to zero. It groups channels into failure domains so that one cause, such as bad lighting, counts once. It requires every core role to be covered, with grace windows for gaps. Section 7 gives the arithmetic.

**The enforcement point** converts trust into capability. It releases short-lived keys, routes or blocks each input, and moves the system between normal, degraded, re-anchoring and duress-shadow states. It sits outside the general-purpose OS. On the lab tier that means the terminal's tamper-responsive secure element streaming signed loop state to a confidential-computing keyserver. On the consumer tier it means a secure element, either the platform's own for per-action key release or a Vault hub (Section 8).

**Anchoring** is the recurring ceremony that connects identity to custody. A strong identity check on an attested sensor binds a freshly attached on-body carrier to the enrolled person, and custody then carries that binding forward. Anchoring looks like a gate, but its role in the loop is different. It is not a door to a session. It is a state transition the loop schedules for itself whenever custody breaks: a band comes off for charging, a patch is replaced, or a contradiction resets the chain. The shipping precedents already work this way. Nymi says workers authenticate about once per shift with fingerprint plus ECG, and trust is then maintained through continuous on-body detection (vendor claim, sponsored content)[9]. Apple's Watch must be unlocked on the wrist before it can unlock anything[1].




**The loop** (proposal). Channels on the body, the device and in the room send signed evidence. Cross-checks bind that evidence to one body and ask whether every input is explained by it. The trust engine lets missing evidence decay slowly but cuts trust to zero on any contradiction. An enforcement point outside the operating system turns the result into short-lived keys, per-input routing and loop state. A strong identity check is not a door at the start. It is a step the loop schedules for itself whenever custody breaks[15, 34].

## The loop runs at several cadences at once

A loop that tried to establish everything at one rate would be either too slow to catch an injected keystroke or too demanding to wear. The proposal below assigns each proposition its own cadence, and each value is a design target, not a measured result.

| CADENCE (PROPOSAL) | WHAT IS CHECKED | TYPICAL EVIDENCE | GROUNDING |
|---|---|---|---|
| **Per input (milliseconds)** | P3: each keystroke, click or command is attributed to owner, agent or nobody | Attested input report plus wrist motion or EMG event; OS path and process identity | NAB attests within about 1 s of input[56]; per-event matching is needed against piggybacking (inference) |
| **Per epoch (1–5 s)** | P1 and custody: on-body carriers report tissue contact and pulse; signed loop state renews the session key | PPG or ECG, skin contact, secure ranging | RATS freshness and watchdog pattern[34]; Apple's ranged unlock[1] |
| **Per minute** | P2 refresh: passive face match on the attested camera when the face is visible; cross-modal pulse coherence | ESS IR face; rPPG versus wearable pulse | Hard biometrics reserved for re-authentication, soft cues for tracking[79] |
| **Per custody break (daily)** | Re-anchor after band removal, charging or a contradiction | Touch ID, ESS face, ECG at don | Nymi and Apple Watch pattern[9, 80] |
| **Per patch (5–15 days)** | Apply a new adhesive or microneedle seal under a strong identity check; refresh physiological templates | Patch application ceremony | Wear limits of patches and CGMs[81, 82, 83] |

| CADENCE (PROPOSAL) | WHAT IS CHECKED | TYPICAL EVIDENCE | GROUNDING |
|---|---|---|---|
| **Per year or event** | Re-enrol templates; review heirs, agents and quorum | Supervised ceremony | Template drift[13, 84]; succession patterns[85] |

## What changes relative to a presence-kept gate

Relative to a presence-kept gate, six things change. Authority shrinks from a session to an input and a few-second epoch, so a lent badge or a stolen token is worth seconds, not hours. The proposition kept alive becomes "these inputs are explained by the owner's attested body", which is what defeats agents posing as the owner, piggybacking malware and handover. Contradictions act at once while missing evidence decays slowly, which spares the idle owner but not the impostor. Re-anchoring becomes a state the loop schedules for itself, not a door the owner must walk back through. Agents become first-class principals instead of invisible passengers in the owner's session. And duress becomes a loop mode: a shadow state that looks normal to an observer.

# Liveness is plentiful, identity is concentrated, custody is a negative signal

Each candidate channel is judged here on four separate properties. Liveness (P1) asks whether it proves a living human is attached. Identity (P2) asks whether it proves *which* human. Custody asks whether it proves the same body has stayed attached since the last strong check. Input binding (P3) asks whether it can tie individual inputs to the body. Few channels score well on more than one property, which is why the loop needs several channels at once. The reason is not that many weak identity signals add up to a strong one, which Section 7 shows they often do not. The reason is that each proposition needs its own kind of evidence.

## On-body channels carry liveness and custody, and rarely identity

**ECG** is the most studied cardiac biometric, and shipping products have moved away from it as an identity anchor. The original Nymi Band identified wearers from the shape of the ECG waveform and stayed authenticated only while worn[86, 87]. Halifax's 2015 bank trial added separate sensors to confirm the wearer had not removed it[88]. Nymi Band 3.0 paired a fingerprint sensor (vendor-claimed false positive rate about 1 in 500,000) with an ECG check that the finger and the wrist belong to one body[89]. The current product page lists only a fingerprint sensor, FIDO2 certification, "continuous authentication" and a battery life of "3+ days" (vendor)[90]. Cross-session drift explains the shift. EDITH's identification fell below 80% on CYBHi, whose sessions are about three months apart[84]. A September 2026 study's 1.7% equal error rate (EER) from rest to peak exercise was measured within one session, and its authors warn that such protocols can confuse identity with electrode placement and posture[91]. Electrodes also accept injected signals. *Broken Hearted* (NDSS 2017) fooled the Nymi Band in 81% of attempts with Nymi-recorded ECG, 62% with mapped ECG from other devices and 43% with raw ECG from other devices, delivered by waveform generators, a sound card or `.wav` files played from an audio player[14]. Requiring heart-rate variability and a simultaneous PPG signal to agree with the ECG defeated these attacks only in the authors' simulations[92]. Apple Watch's ECG app needs a deliberate 30-second finger touch and has no identity function[93]. Prescription patches record continuously for 7–14 days (Zio field wear averages 12.6 days) and have no identity function either[81, 94, 95]. ECG therefore works best at don time, as a same-body check ("this finger and this wrist share one heart"), and then as a waveform that must stay coherent with a second cardiac channel (inference).

**PPG** (optical pulse) is the most available continuous signal and the weakest identifier. The best real-world evaluation tracked 44 students over 13 weeks. Methods that scored well on lab datasets collapsed: one fell from MCC 0.94 to 0.44, another from 0.70 to 0.09. Training on the first half of the semester and testing on the second dropped identification to MCC 0.07–0.08[13]. NDSS 2026's wrist-PPG continuous-authentication study reports 88.11% accuracy, a 2.76% EER and an 11.77% false-reject rate across 26 subjects. Its models were specific to each physical device, so a replacement watch means re-enrollment, and spoofing was not evaluated[96]. No study tested identification from a smart ring alone. The closest work verifies ring or watch PPG against the face's camera-measured pulse, at 95.5% balanced accuracy with 33 subjects, which binds a wearable to a face rather than identifying a person[97]. PPG's value is liveness and removal: a pulse that disappears means no tissue. Its weakness is people. Apple confirmed in 2015 that dense dark wrist tattoos can interfere with the heart-rate sensor, enough for the watch to think it is off-wrist and lock[98].

**On-body custody** is the shipping pattern, and its transfer gap is the attack surface. Apple Watch "locks automatically soon after it's removed from the user's wrist" when wrist detection is on, and device management can enforce the setting[80]. Auto Unlock connects over Bluetooth LE and then uses peer-to-peer Wi-Fi to "securely approximate the distance", sending its unlock secret through a mutually authenticated protocol that terminates in both Secure Enclaves[1]. Android's accelerometer-only on-body detection is the cautionary case: it cannot recognize who holds the phone, so a handed-over phone stays unlocked[44]. A US patent on persistent authentication compares optical and capacitive sensor signals and notes that redundant sensors make a wearable "more difficult to trick"[99]. This research infers that transfer resistance

depends on three things: how many independent continuity sensors there are, whether one of them carries identity (an ECG or pulse-shape template that breaks coherence on a swap even if skin contact is kept), and how fast the session dies after a break. No source describes a wearable that *cryptographically proves* it never left the body. Custody is always a negative signal: no break detected.

**Surface EMG** is the only on-body channel that could plausibly serve liveness, identity and input binding at once, and it is locked inside one ecosystem. Meta's *Nature* 2025 paper trained generic decoders that work across people from a "highly sensitive, easily donned sEMG wristband" and thousands of participants. It reports a median 0.88 gesture detections per second and 20.9 words per minute of handwriting, with personalization improving handwriting by 16%[100]. The Meta Neural Band shipped with Ray-Ban Display glasses at $799 in the US from 30 September 2025. Telekom has sold the bundle in Germany since 13 October 2026, and the band is not sold separately[101, 102]. As a biometric, wrist EMG reached a median multi-day EER of 2.5% on GRABMyo (43 participants, 3 days)[103], and 1.1% with a user-customized gesture code[104]. A review cautions that most EMG-biometric studies have fewer than 25 subjects, the larger ones use a single day, and electrode shift, sweat and exercise degrade consistency[105]. Forearm EMG fires before a keystroke, and an observer cannot see it to imitate it. That makes EMG the most promising signal for binding input to the wearer. **No paper validates EMG-to-keystroke attribution as a security primitive** (inference and gap). This research found no public API that lets a PC pair with the Neural Band (gap).

**Ear and head** channels offer passive identity in narrow form factors. NEC's ear-canal acoustic authentication measures resonance in about one second and claims above 99% accuracy (vendor claim). Its Hearable Device went on sale in Japan in 2020[106, 107]. University at Buffalo's EarEcho reached about 95% at one second and 97.5% with continuous monitoring, but on 20 subjects[108]. Apple Vision Pro shows the target behaviour in a headset. Optic ID claims a random-person false match below 1 in 1,000,000 (vendor claim), and removing the headset locks it[75, 109]. Apple does not document whether Optic ID re-checks during a session. Meta's Ray-Ban Display glasses have no eye tracking and so cannot contribute iris identity[110].

**Implants** are possession tokens under the skin. VivoKey Apex is an NFC secure element running a FIDO2 applet, vendor-claimed to Common Criteria EAL6+[72]. It proves possession of a key at centimetre range. It does not prove liveness, since a chip answers just as well from a severed hand or a cadaver, and it cannot be read continuously from a laptop (inference). Washington's HB 2303 (2026) bars employers from requiring microchip implants and gives workers a right to sue, and at least a dozen states have similar laws[111, 112]. Implants can only ever be an optional extra factor for either tier.

## The blood-sample verdict: no continuous identity, but the strongest custody seal

The founder's suggestion of "a blood sample" deserves a precise answer, because it contains one idea that fails and one that is better than it looks.

As **continuous identity**, blood fails on every axis the loop needs. DNA is definitive, but the FBI-approved Rapid DNA booking system takes about 90 minutes to process, enroll and search a sample (vendor release)[6]. DNA is also not a secret. In a 2024 University of New Hampshire study, one person's DNA transferred to a second person's hand in 50% of trials[21], so holding a matching sample proves little. For relatives, DNA is probabilistic. Even at 40 STR loci, half-siblings showed 5–7% false inclusion or exclusion[113]. Biochemical signatures are only partly individual. In the KORA cohort, metabolic profiles uniquely identified just over 40% of 818 participants after seven years[22]. Infrared fingerprints of serum and plasma were "highly stable" within individuals over six months, but in a 31-person study using laboratory instruments[114]. A 2021 conference abstract claimed individuals could be recognized from continuous glucose traces, but its accuracy could not be verified[115]. No glucose stream identifies a person in real time.

As a **custody and liveness seal**, a minimally invasive sensor is the best on-body channel available. The FDA's decision summary for Biolinq Shine, the first autonomous microneedle glucose sensor (De Novo, September 2025), says the device is worn on the inner forearm only, is single-use, and "cannot be re-applied if it falls off"[7, 116]. First-generation wear is battery-limited to about five days[83]. Filament CGMs run 15 days. Dexcom's G7 15 Day is indicated for 15.5 days, but only 73.9% of sensors lasted the full period in Dexcom's study, and each needs a 60-minute warm-up[82, 117]. A sensor that sits partly inside the body, breaks physically on removal, cannot be re-applied, and streams interstitial chemistry that a dead or synthetic surface would not produce is far harder to move to another body than a clasped band. This research infers a design. Apply the sensor during a strong identity ceremony, pair it cryptographically to Vault, and treat the session as valid only while it reports physiologically plausible data. That makes a 5–15-day custody seal. It proves P1 and custody, never P2.

Three caveats bound the idea. First, no CGM maker documents a security-grade removal event. Removing a Dexcom sensor is described only as peeling it off "like a bandage", which ends the session[23]. Removal latency is unknown, and no study has tried spoofing the sensor's "living tissue" signal, for example in a glucose solution. Vault would need vendor cooperation or custom hardware. Second, adhesives cause allergy. In a 2024 Swedish study, about 63% of 54 diabetes patients referred for suspected device dermatitis were allergic to isobornyl acrylate, against 0.2% of general dermatitis patients. That is a referred population, not a prevalence figure[118]. Third, the cadence is a burden. Reapplying every 5–15 days, plus early failures, means roughly 25–50 identity ceremonies a year (inference). Glucose is also health data, which Section 11 shows carries its own legal weight. The verdict is to offer the microneedle seal as an optional high-assurance custody carrier, for example for a crypto signing session or a lab operator's shift. It should never be a required channel. A one-off lab draw at enrollment or succession adds little that a supervised in-person ceremony with documents and fresh biometric enrollment does not already provide. Sections 10 and 11 explain why DNA should not gate heirs.

## Device-side channels supply identity and the input events themselves

**Infrared face on an attested path** is the strongest shipping passive identity channel on a laptop, and it exists only on Windows. With Enhanced Sign-in Security (ESS), Windows runs face matching in virtualization-based security (VBS). The hypervisor lets only the face camera write into protected memory, templates are encrypted under keys only VBS holds, and a successful match authorizes Windows Hello keys through a secure channel to the TPM[74]. ESS is on by default on all Copilot+ PCs. It "isn't supported for external camera modules", and on multi-user devices the lowest Windows Hello posture applies[74, 119]. Macs had no Face ID as of late 2025, when Bloomberg reported it "remains years away" (secondary)[120]. Continuous face presence on a Mac would therefore be third-party software without an isolated camera path. Microsoft does not document whether ESS can re-verify continuously rather than only at sign-in (gap).

**Fingerprint in the keyboard** is the reference design for an attested peripheral. The Magic Keyboard with Touch ID stores no templates. Matching happens in the Mac's Secure Enclave, the keyboard attests with a hardware public-key accelerator, and Touch ID data travel AES-GCM encrypted over ephemeral ECDH[15]. Apple makes these claims only for Touch ID data, not for ordinary keystrokes, and a read needs an explicit touch. Fingerprint sensing under every typing key exists only in a patent[121]. A 2005 research system put a fingerprint reader in the mouse and fused it with camera face verification over time[122]. Fujitsu's palm-vein mouse needs the palm held about two inches above the sensor, so it suits a challenge, not continuity[123].

**Behaviour and gaze** are passive but slow and forgeable. Mondal and Bours' trust model needed an average of about 275 actions to detect an impostor[124]. Conditional generative models now synthesize keystroke dynamics that fooled an external authentication system[125]. Eye-movement biometrics stayed reliable over two weeks against "lunchtime" attackers[126]. Their errors concentrate on particular users, so a good mean EER can hide a few owners who are locked out constantly[127]. Tobii Aware ships eye-tracking presence, auto-lock and a "Continuous ID" refocus feature on Lenovo, Acer and MSI machines (vendor)[128]. These signals belong in the loop as low-weight corroboration. They also carry legal weight, because Washington counts keystroke rhythms as biometric health data (Section 11).

## Ambient channels report the room, not the person

**Webcam pulse (rPPG)** is a conditional channel. Under controlled lighting, classical methods estimate heart rate within about 2 BPM on the standard benchmark[129]. Models tested on the mobile, mixed-skin-tone, mixed-lighting MMPD dataset err by 9–18 BPM[130, 131]. Intel claims 96% accuracy for its rPPG-based FakeCatcher (vendor claim). An informal BBC test reportedly found it flagged several real videos as fake (secondary)[132, 133]. Its role is a cross-check, never a channel that must always pass.

**Millimetre-wave radar** ships for presence. Google's Nest Hub senses breathing with Soli radar[134], and Infineon markets 60 GHz presence parts for notebooks, PCs and monitors (vendor)[135]. Vital signs need stillness. In TI's user forum, staff said the person must stay still for at least 30 seconds facing the antenna (user forum material)[136]. Radar identification is lab-only. Cardiac Scan reported 98.61% balanced accuracy and a 4.42% EER on 78 subjects[137]. Radar identification is also spoofable: researchers synthesized cardio-respiratory signatures with a phase shifter driven by a signal generator, and replayed recorded chest motion through an actuator hidden under clothing[73, 138].

**Presence and second-person detection** complete the ambient group. Windows presence sensing targets under 5% false wakes and under 5% missed wakes. It is unavailable on some machines with the lid closed or an external display attached[47, 139]. Commercial continuous-face agents lock on "additional or unknown faces in the frame" (vendor)[11]. Presence must never count as identity. It is a trigger: start a grace timer when presence drops, and demand re-verification when it returns.

## Scorecard: three channels carry hard identity, none carries input binding

The matrix below is this report's synthesis of the evidence above (inference, not a measured benchmark). "Strong", "moderate" and "weak" compare channels with each other for the stated property. They are not certified ratings.

| CHANNEL | LIVE BODY (P1) | IDENTITY (P2) | CUSTODY | INPUT BINDING (P3) | STRONGEST ATTACK EVIDENCE | CONSUMER AVAILABILITY | LOOP ROLE (PROPOSAL) |
|---|---|---|---|---|---|---|---|
| **Wrist ECG band (Nymi-style)** | Strong | Moderate at don; drifts across sessions[84] | Needs separate on-body sensor | None | Injection 43–81%[14] | Enterprise only | Don-time same-body check; cardiac coherence |
| **Chest ECG patch** | Strong | None offered | Adhesive seal, 7–14 days[81] | None | Unstudied | Prescription only | Lab-tier custody seal option |
| **Watch or ring PPG** | Strong | Weak in the field[13] | Good (tissue presence) | Weak (motion) | Optical injection unstudied | Ubiquitous | Core custody carrier; liveness |
| **Wrist detection plus secure ranging (Apple Watch)** | Implicit | Inherited from unlock | Locks on removal; 2–3 m ranging[1] | None | MitM on Auto Unlock (2017, status unknown)[67] | Mac only | Core custody carrier on macOS |
| **sEMG band** | Strong | About 2.5% EER multi-day (lab)[103] | Good | Promising, unvalidated | Unstudied | Bundled with Meta glasses only | Research channel for P3 |

| CHANNEL | LIVE BODY (P1) | IDENTITY (P2) | CUSTODY | INPUT BINDING (P3) | STRONGEST ATTACK EVIDENCE | CONSUMER AVAILABILITY | LOOP ROLE (PROPOSAL) |
|---|---|---|---|---|---|---|---|
| **Microneedle or CGM sensor** | Strong (live interstitial fluid) | None | Single-use, cannot re-apply[7] | None | Unstudied | OTC CGMs; no security API | Optional high-assurance seal |
| **DNA or metabolome** | Not applicable | DNA definitive but ~90 min[6] | None | None | DNA is shed[21] | Lab only | Excluded from the loop |
| **NFC or FIDO implant** | None | Possession of a key | None (centimetre tap) | None | Passive chips clonable | Biohacker niche | Optional extra factor only |
| **Ear-canal acoustics** | Moderate | Above 99% (vendor claim); 95–97.5% on 20 subjects[106, 108] | Good (ear seal) | None | Unstudied | Japan only | Optional passive identity |
| **Headset iris (Optic ID)** | Yes | Below 1 in 1M FMR (vendor claim)[75] | Locks on removal | None | Not in sources | Vision Pro | Lab option for headset users |
| **IR face on attested path (ESS)** | Moderate (IR) | Strong | Only while face visible | None | IR photo (older builds), USB IR-frame injection[63, 64] | Copilot+ PCs; built-in only | Core identity anchor and refresh (Windows) |
| **RGB webcam face** | Weak | Strong matcher, unattested path | Only while visible | None | Virtual cameras, deepfakes[62] | Universal | Telemetry; may only lower trust |
| **Touch ID keyboard or ESS fingerprint** | Weak | Strong (vendor-claimed FAR below 1 in 50,000 for Touch ID)[140] | None | One bit per touch | Match-on-chip bus MITM (patched)[141] | Mac, Windows | Core identity anchor; secure-intent gesture |
| **Per-key fingerprint** | Weak | Strong in principle | None | Strong in principle | None (patent only) | No | Phase 3 research |
| **Keystroke and mouse dynamics** | None | Weak; ~275 actions to flag[124] | None | Weak | GAN-forged keystrokes[125] | Software | Low-weight corroboration |
| **Gaze (eye tracker)** | Moderate | Moderate; per-user systematic errors[127] | Only while looking | None | Not evaluated | Tobii Aware laptops | Optional corroboration |
| **Webcam rPPG** | Moderate when still | None | None | None | Deepfakes carry the driver's pulse[16] | Universal | Cross-check only, never must-pass |
| **mmWave radar** | Moderate (breathing) | Lab-only, spoofable[137, 138] | Seat presence | None | Phase-shifter and actuator replay | About $60 sensor[142] | Presence and timing cross-check |

| CHANNEL | LIVE BODY (P1) | IDENTITY (P2) | CUSTODY | INPUT BINDING (P3) | STRONGEST ATTACK EVIDENCE | CONSUMER AVAILABILITY | LOOP ROLE (PROPOSAL) |
|---|---|---|---|---|---|---|---|
| **Wrist motion vs input (ZEBRA-style)** | Weak | None | None | Moderate if trusted-channel-driven | Opportunistic mimicry ~40%[19] | Watch IMU | P3 corroboration, per event |

Three patterns stand out. Liveness is available from almost every on-body and ambient channel. Identity comes almost entirely from three hard biometrics on attested paths (IR face, fingerprint, iris), and only IR face is passive at a desk, only on Windows, and only with a built-in camera. Input binding has no mature channel at all. Those gaps shape the reference builds in Section 8.

## Wear burden decides whether a channel stays on

A channel that is not worn proves nothing, and wear compliance is the binding constraint for consumers. In Pew's most recent data (2019), about 21% of US adults regularly wore a smartwatch or fitness tracker, rising to 31% in households earning $75,000 or more[143]. Gartner found that 29–30% of smartwatch and tracker owners had abandoned them[144]. Apple Watch Series 11 is rated at up to 24 hours (vendor claim), and the Neural Band at about 18 hours, so a single wrist carrier drops out of the loop every day while it charges[145, 146]. Accessibility cuts across channels. Industry experience is that about 1–2% of people have unusable fingerprints, and capture quality falls sharply after age 65[147, 148]. Tattoos defeat wrist PPG, and adhesives aggravate itch-prone skin[98, 149]. This research draws the consequence: a consumer Vault needs *equivalent assurance bundles*, for example face plus watch, fingerprint plus ring, or fingerprint plus patch, so that a tattooed, elderly or adhesive-allergic owner can reach the same trust by a different route. A fixed set of required devices would exclude roughly 1–5% of users by construction (inference).

# Agreement proves one body, never whose body

## What agreement between channels proves

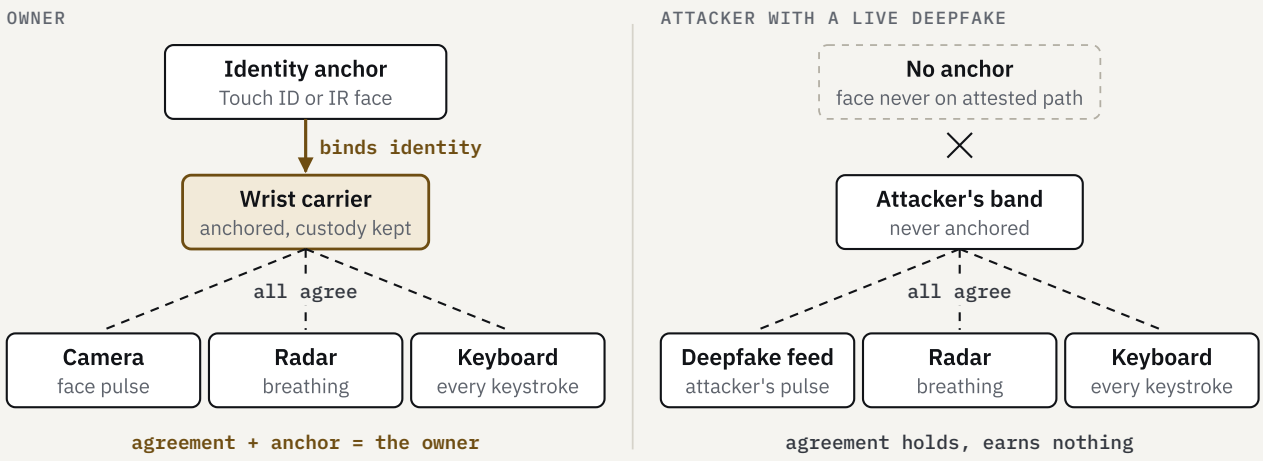
Checking that one physiological event looks the same to two independent sensors is a well-tested security primitive. FaceHeart (INFOCOM 2017) compared the pulse in front-camera face video with the pulse from a fingertip on the rear camera. Against an attacker who replayed the victim's face video on a tablet while covering the rear camera with their own finger, it detected 94.71–98.24% of 340 attack instances. Its EER rose to 8.54% when a gaming task raised heart rate[71]. Heart-to-Heart (CCS 2013) grants a programmer access to an implanted medical device only while both devices record matching ECG, so access lapses the moment physical contact ends[150]. H2B derives a shared key from heartbeat intervals seen by cheap vibration sensors at different body sites, with 95.6% pairing success across 23 participants[151]. Together these show what agreement proves. When independent sensors on the wrist, in the camera and in the radar report the same beat with the right delays, they are almost certainly observing one living body, and that body is in contact with or in view of each sensor.

## What agreement does not prove

Agreement does not prove whose body it is. "High-quality deepfakes have a heart!" (Frontiers in Imaging, 2025) found that the heart rate visible in a face swap tracks the heart rate of the person driving it, with r = 0.89 for DeepFaceLive, a real-time tool. The authors conclude that the assumption that deepfakes lack a pulse "is no longer valid". Their own dataset had only 12 people[16]. PulseEdit (IEEE TIFS 2022) edits the pulse in face video without visible change, removing it or inserting a chosen signal, and its authors state it circumvents rPPG-based liveness and deepfake detection[17]. A 2025 method claims to edit physiological signals stably across head motion and skin tones[152]. The consequence for Vault is direct. Suppose an attacker drives a real-time face swap of the owner while wearing a wristband. The webcam pulse and the wrist pulse will agree perfectly, because both are the attacker's heartbeat. rPPG-to-wearable agreement proves that a live heart sits behind the video and that the same body wears the sensor. It does not prove that the face belongs to the owner.

Remote observation also leaks the signals that agreement relies on. Seepers et al. showed that camera-based pulse measurement recovers inter-pulse intervals about as accurately as contact PPG, a "substantial threat" to heartbeat-based security derived from contact PPG. It could not accurately reproduce identifiers derived from electrical ECG signals[153]. Periodic signals can be replayed into sensors, as the radar actuator attack shows[73]. ECG electrodes accept injected waveforms[14]. Every one of these attacks targets a channel whose signal is periodic, observable or physically reachable by the attacker.

The resolution lies in the loop's structure, not in any single check (inference). Identity enters the loop only through a hard biometric on an attested sensor at an anchor event, such as an ESS face match or a Touch ID press. The on-body carrier is attached and bound at that moment. Custody then carries the binding: a band taken from the owner's wrist breaks custody and goes dead, so an attacker cannot wear the owner's anchored carrier. Cross-modal agreement then does the job it can do, which is to bind the face, the inputs and the room to *that anchored body*. In the deepfake scenario above, the attacker's wristband was never anchored to the owner, and the attacker's face never passed the attested camera, so agreement between the attacker's own channels earns nothing. The scenario that remains hard is an attacker who obtains the owner's *live* beat timing remotely and injects it into a forged stream in real time while the owner's anchored carrier is elsewhere. No public work demonstrates that end to end, but its pieces exist[17, 153]. The loop's defence is to require that the face itself arrive over an attested path, and to use timing that a forged stream must match to the millisecond.




**Agreement binds; the anchor identifies.** When the wrist, the camera, the radar and the keyboard tell one consistent story, they are almost certainly watching one living body. They are not proving whose body it is. A real-time face swap carries the pulse of the attacker driving it, so an attacker's own band agrees with their deepfake perfectly[16, 17]. Identity enters only through a hard biometric on an attested sensor, which anchors the carrier. Custody then carries that anchor forward, and cross-checks bind everything else to the anchored body.

## What ZEBRA's failure teaches about binding inputs

ZEBRA (IEEE S&P 2014) is the closest prior attempt at the loop's third proposition. A bracelet on the dominant wrist streamed motion. The terminal classified it into typing, scrolling and keyboard-to-mouse switching, and kept the session only while these matched the actual input events[154]. It verified 85% of legitimate users while identifying all adversaries within 11 seconds, or 90% within 50 seconds at a more lenient threshold[154]. Huhta et al. (NDSS 2016) broke it. Their opportunistic attacker watched the victim at a nearby terminal and mimicked only the interactions they could copy reliably, typically starting to type after the victim started and stopping early. A keyboard-only opportunistic attacker had 70% of windows accepted, and "almost half of the attackers" stayed logged in for the whole experiment. Legitimate users were rejected in only 0–6% of windows, and none was logged out in any 10-minute sample[18]. Aalto's summary reports that opportunistic attackers evaded detection 40% of the time[19]. The root cause, in the authors' words, was "tainted input". The attacker controlled the input sequence and, through its timing, *when* the victim's bracelet data were segmented and compared. ZEBRA also ignored bracelet data whenever the terminal saw no input, a privacy choice, and the authors warn that "pre-mature optimization motivated by privacy ... may introduce security vulnerabilities"[18]. WACA, a later smartwatch-based system, reports about 1% error with 30 seconds of data and robustness to imitation by attackers watching video of the victim. Those are the authors' own figures[155].

## Design rules for the loop's cross-checks

The rules below are this report's synthesis. Each comes from a specific attack.

| RULE (PROPOSAL) | ATTACK THAT TAUGHT IT | HOW VAULT APPLIES IT |
|---|---|---|
| **1. The trusted channel drives every comparison** | ZEBRA: attacker's input chose when comparisons ran[18] | Wearable and ambient streams run continuously; the verifier asks whether each input is *explained* by them, not whether the wrist matches selected inputs |
| **2. Unexplained activity and unexplained absence both count against the session** | Attacker types while the victim uses the mouse; ZEBRA ignored the bracelet when the terminal was idle[18] | Keystrokes without wrist or muscle events, and wrist typing motion without keystrokes, both cut trust |
| **3. Compare every event, at per-event granularity** | Selective mimicry; piggybacking on human activity[18, 56] | Each keydown is matched to a wrist or EMG micro-event; no attacker-selectable sampling |
| **4. Attest every sensor, and physically bind it to the body** | ECG injection through electrodes[14]; USB IR-frame injection[63] | Sensors pair to the enforcement point with attested keys (Magic Keyboard pattern)[15]; on-body detection guards the skin interface |
| **5. Agreement binds; identity authenticates** | Deepfakes inherit the driver's pulse[16] | Identity enters only through a hard biometric on an attested path at anchor events, then rides custody |
| **6. Prefer aperiodic and challenge-driven signals** | Heartbeat and breathing replay[73, 153] | Weight keystroke-to-muscle timing and verifier-issued challenges (randomized illumination, LED patterns) over steady rhythms; speech-synchronized signals are harder to fake[156] |
| **7. Keep raw signals for verification but never export them** | ZEBRA's privacy shortcut[18]; EMG and motion leak passwords[157, 158] | Process continuously inside the enforcement point's trusted environment; release only verdicts |
| **8. Use fixed physiological lags as anti-forgery timing** | FaceHeart lists face-to-finger delay as future work[71] | Require the ECG R-peak to precede the facial pulse by a body-specific delay. This is an untested design idea, and no source gives the tolerance |

Rule 8 deserves a caution. The fixed delay between the heart's electrical beat and the arrival of the pulse at the face is a check a forged video would have to reproduce with millisecond timing through any processing pipeline. It is attractive precisely because it is physical. No source measured its stability in a seated user, and no source has tested it against attack, so it belongs in the research plan, not in the v0 design.

# Attribute every event to the owner, the owner's agent, or nobody

The third proposition, that the inputs come from the attested body, is the newest requirement and the least mature. It is also the one that separates a loop from a presence-kept gate. It must handle three different sources of non-owner input. Malware and remote attackers want to pass as the owner. Injected devices want to pass as hardware. The owner's own AI agents are legitimate but are not the owner.

## Operating systems can flag synthetic input but cannot vouch for a human

Both mainstream desktop platforms record *how* an input event entered the system. On Windows, low-level hooks see `LLKHF_INJECTED` and `LLMHF_INJECTED` flags on events injected through user-mode APIs. `SendInput` is subject to User Interface Privilege Isolation, so a process can inject only into applications at an equal or lower integrity level, and blocked calls fail without any error code saying why[57, 159]. On macOS, posting synthetic events requires a distinct PostEvent privilege that shows up under Accessibility, separate from Input Monitoring[58]. Patrick Wardle reported that macOS 10.14 began ignoring synthetic events globally unless the user grants the app permission; his earlier bypasses had clicked through protected security prompts[60]. These signals describe a software path. An administrator can load a kernel virtual-HID source driver whose reports travel the same class-driver stack as a physical keyboard[24], and a malicious USB device needs no software at all[25]. This research concludes that provenance flags are a **cooperative signal for honest software**, useful for routing input from agents that announce themselves, and not a security boundary against an attacker with admin rights (inference).

The agent question sharpens this. Claude Code's desktop computer use needs Accessibility and Screen Recording on macOS[26]. A remote-access trojan uses the same permission. The operating system can answer "was this event synthetic?" but not "which synthetic source, acting for whom?" (inference). Cloud agents such as Operator act from a remote browser and never generate input on the owner's machine at all[53]. An input-layer loop cannot see them, so their authority has to be governed at the account and service layer.

## Research built trusted input paths, and found that input integrity needs output integrity

No shipping consumer platform cryptographically attests ordinary keystrokes. What ships are narrow, hardware-rooted intent and biometric channels. Apple's **secure intent** is "a physical link—from a physical button to the Secure Enclave", designed to confirm a user's intent "without any interaction with the operating system or Application Processor" and to resist software with root or kernel privileges. It ships on Apple-silicon Macs, recent iPhones and iPads, Apple Watch and Vision Pro, and is used for Apple Pay and keyboard pairing[28]. The Magic Keyboard encrypts and attests only Touch ID data[15]. ESS protects only the biometric pipeline[74]. Microsoft's Pluton documentation makes no claims about keyboard or mouse paths (vendor documentation)[160]. The USB-IF Authentication Specification defines certificate-based authentication of USB devices. It authenticates a device's identity, not individual reports, and the research found no evidence of a profile for keyboards and other human-interface devices, or of operating-system adoption[161].

Research systems built the missing path and documented its limits.

| SYSTEM | MECHANISM | WHAT IT PROVES | LESSON FOR VAULT |
|---|---|---|---|
| **Not-a-Bot (NSDI 2009)** [56] | ~500-line attester in the Xen hypervisor reads keyboard and mouse directly; TPM-sealed key signs request hash, nonce and time since last input; anonymous attestation | Real input occurred within about 1 s of the request | Bots can still piggyback on human activity at human rates; origin of a specific action is not proven |
| **Bumpy (NDSS 2009)** [162] | Keystrokes handled in an isolated Flicker module; user marks sensitive input with `@@` | Marked input bypassed the legacy OS | An 85-person, four-month study found it "requires extra diligence from users"[163] |
| **Fidelius (IEEE S&P 2019)**[164] | SGX enclave with a trusted path from input and output peripherals | Secrets protected even if browser and OS are fully attacker-controlled | Trusted path is feasible on commodity CPUs, but depends on enclave security |
| **IntegriKey**[76] | External device signs input parameters | Input integrity | Without output integrity, UI manipulation tricks the user into entering the wrong thing |
| **ProtectIOn (NDSS 2020)**[76] | Low-TCB device inline between host and IO devices; intercepts HDMI and keyboard and mouse; overlays secure UI | Input and output integrity together, without relying on users checking indicators | The template for an inline Vault input device |

Two lessons carry into the loop (inference). Attesting that a human recently typed limits the rate of bot actions but does not prove the origin of any particular action, so the loop needs per-event binding. Protecting input without protecting what the human saw lets malware redirect a genuinely human click, so a confirmation for a consequential action should be rendered by the enforcement point, not by the general-purpose OS. ProtectIOn's inline device satisfies both. It is the closest research analogue to a Vault hub that sits between a desktop's keyboard, mouse and display and the computer.

## Body binding turns provenance into a per-event score

Binding each input to the wearer's body converts input provenance from "a keyboard sent this" to "the owner's hand did this". The evidence supports a scored claim, not a cryptographic proof. CSAW, a successor to ZEBRA, uses "temporal features that require any adversary to synchronously mimic the owner"[165]. Venugopalan et al. used forearm EMG as a typing biometric precisely because "keypress timings alone are very easy to spoof"[77]. The same signals leak secrets. *My(o) Armband Leaks Passwords* reached about 76% mean balanced accuracy for keystroke detection, with EMG the most informative channel, over a dataset of more than 310,000 keystrokes[157], and smartwatch motion sensors can infer keystrokes on numeric touchpads[158]. Behaviour alone is not enough either: generative models now forge keystroke dynamics well enough to fool an external authentication system[125].

This research proposes a per-action human-origin attestation of this form: "keystroke *k* at time *t* coincided with a muscle or wrist-motion event in the owner's anchored wearable, with correlation *c*". It is signed at both ends, by an attested input path and by the wearable's own key. Signing both endpoints turns ZEBRA's tainted-input problem into a cross-device consistency check. A fully synthetic stream would then have to forge two hardware-signed sources (inference). The residual attacks are bounded. A nearby human mimic defeats coarse correlation, but Vault's main threat is non-human input, which a mimic does not produce. Malware that times injected input to coincide with the owner's real typing defeats window-level correlation, which is why rule 3 in Section 5 requires per-event matching. And because the signals that make binding possible also leak passwords, raw EMG and motion must stay inside the enforcement point's trusted environment.

## Personhood credentials prove something different

The anti-bot ecosystem offers proofs that look relevant and are not.

| MECHANISM | WHAT IT PROVES | WHAT IT DOES NOT PROVE |
|---|---|---|
| **CAPTCHA, Cloudflare Turnstile**[55, 166] | A browser session looked human or legitimate at one moment | Anything, against modern solvers: reCAPTCHAv2 was solved 100% of the time[55] |
| **Private Access Tokens (Privacy Pass)**[167, 168] | An attested, unmodified device or platform account obtained a token; unlinkable by design | That a human, let alone the owner, produced an input |
| **World ID**[169] | The holder has a credential issued to one unique human (iris-verified at an Orb) | That the enrolled human is the one acting now; World's AgentKit deliberately extends it to the human's agents |
| **Personhood credentials**[170] | The holder is a real person, without disclosing who | Per-input authorship; the authors argue CAPTCHAs are inadequate against AI |

All four are bearer proofs issued at a moment, mostly unlinkable for privacy, with no binding to an input stream. They suit Vault's *outward* face, for example attaching a "verified human principal" claim when an owner-authorized agent acts on the web. They do not serve the local question of who is at the keyboard (inference).

## Three principals, and confirmations the agent cannot press

The industry is converging on a pattern Vault can adopt directly. Agents are distinct principals that act under scoped, auditable delegation rooted in a human-signed intent, and they need fresh human presence for consequential steps. Windows 11 gives agents "dedicated agent accounts distinct from the user account" and an "agent workspace" with its own desktop. It requires agents to be "signed by a trusted source so that maliciously or poorly behaved agents can be revoked", and runs Copilot Actions under the agent account to separate "the work done by the agent from other actions on the system"[27, 171]. OAuth Token Exchange records who acts for whom in an `act` claim[30], and an individual draft extending it to AI agents expired in February 2026[172]. Google's AP2 separates a **human-present** flow, in which the user's approval signs a Cart Mandate, from a **human-not-present** flow bounded by an upfront Intent Mandate, creating "a non-repudiable audit trail"[29]. Visa's Trusted Agent Protocol signs agent requests in line with the IETF's Web Bot Auth work, and Mastercard Agent Pay issues per-agent tokens confirmed with payment passkeys[173, 174, 175]. NIST's NCCoE and the Decentralized Identity Foundation both opened agent-identity work in 2026[176, 177].

Mapped onto the loop, every input or action falls into one of three classes (proposal):

| PRINCIPAL | HOW THE LOOP RECOGNIZES IT | WHAT IT MAY DO | CONSUMER EXAMPLE | LAB EXAMPLE |
|---|---|---|---|---|
| **Owner-present** | Attested input path plus per-event body binding plus anchored custody; P1–P3 hold | Everything the owner's policy allows; consequential steps confirmed by secure intent | Owner signs a wallet transaction with a Touch ID double-press | Operator queries a model inside a confidential VM |

| PRINCIPAL | HOW THE LOOP RECOGNIZES IT | WHAT IT MAY DO | CONSUMER EXAMPLE | LAB EXAMPLE |
|---|---|---|---|---|
| **Owner's agent** | Signed agent binary under a distinct OS account or workspace, holding a delegation token whose root is an owner-signed mandate | Only what the mandate scopes; never vault keys directly; escalates to owner-present confirmation for anything irreversible | Desktop agent drafts email and files in an agent workspace; cannot open the vaulted partition | Operations agent runs evaluations on mock or quarantined weights; cannot trigger egress |
| **Unattributed** | Synthetic or HID input that matches neither class, or input with no body binding while the owner's carrier shows idle hands | Nothing: blocked, logged and counted as a contradiction | Rubber Ducky or remote-access trojan typing into a terminal | Kernel virtual-HID driver on a compromised jump host |

Confirmation only means something if the agent cannot press the confirm button. Anthropic's guidance asks developers to have a human confirm decisions "that might result in meaningful real-world consequences"[178]. Claude Code's desktop implementation consumes the Escape key "so prompt injection can't use it to dismiss dialogs"[26]. Wardle's macOS bypasses showed why on-screen confirm buttons are not enough: synthetic events once clicked through security prompts[60]. Vault's confirmations for consequential actions should therefore use a hardware secure-intent gesture or an attested biometric match, as Mastercard uses passkeys. The confirmation dialog itself should be rendered by the enforcement point (proposal).

The two tiers apply the model differently. A consumer owner wants agents to work, so the loop's job is containment. The agent runs in its own account and workspace, its synthetic input is routed there, and the vaulted zone (keys, wallets, the password store) never accepts agent input. Each vaulted action needs an owner-present confirmation. At a lab, agents increasingly operate the infrastructure around weights. The agent's workload identity must be distinct from every human operator's. No mandate may grant weight egress. Any agent-initiated step toward export enters the same human quorum and delay as a human request (Sections 8 and 9). For both tiers, the loop should record which principal produced each consequential action in a tamper-evident log, as NIST, the KYA proposals and AP2 all ask[29, 176].

# Require every role, give every channel a veto, and let none vouch alone

## Combining biometrics can make them worse

The intuition behind "all channels must be on", that more required channels means more security, runs into a classical result. Daugman's analysis of decision-level fusion gives the rules. Under AND, false accepts multiply (FA = FA1·FA2) but false rejects add (FR = FR1 + FR2 − FR1·FR2). His worked example combines a weak test (crossover error 1 in 100) with a strong one (1 in 1,000). The strong test alone makes 200 errors in 200,000 trials, and the AND or OR combination makes 1,100, which is 5.5 times worse. "A strong biometric is better alone than in combination with a weaker one", unless the weaker test's operating point is moved so its false-reject rate falls below twice the strong test's crossover rate[20]. Patent literature calls Boolean AND and OR fusion at fixed thresholds "easily shown to be suboptimal"[179]. The continuous-authentication literature took the alternative route of temporal and score-level fusion. Dynamic Bayesian networks fuse face and mouse-fingerprint evidence across time[122]. Uncertainty-propagating models fuse face, voice and fingerprint scores[180]. Per-action trust models raise and lower trust with every input[124]. Some systems reserve hard biometrics for enrollment and re-authentication and track continuity with soft cues[79].

## The arithmetic of a strict AND

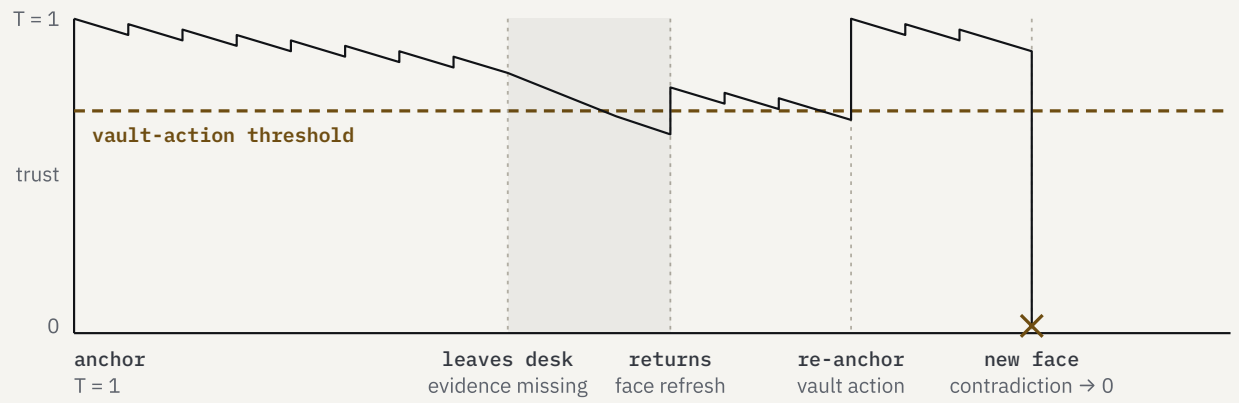
This research works the failure arithmetic for a loop that checks every 10 seconds over an 8-hour day (2,880 checks), assuming independent errors, which is optimistic. With *n* channels each falsely failing with probability *p*, a strict AND fails a check with probability 1 − (1 − p)^n. A grace rule that locks only after *g* consecutive failed checks brings the expected daily lockouts to roughly 2,880 · q^g, where *q* is the per-check failure rate. The extra rows below extend the worked cases using the same formula.

| CONFIGURATION (INDEPENDENT ERRORS ASSUMED) | PER-CHECK FALSE-FAIL RATE Q | GRACE G | EXPECTED FALSE LOCKOUTS PER 8-HOUR DAY | ADDED LATENCY BEFORE MISSING EVIDENCE LOCKS |
|---|---|---|---|---|
| **5 channels at 1%, strict AND** | 4.9% | 1 | About 141 | 10 s |
| **5 channels at 1%** | 4.9% | 3 | About 0.34 (one every three days) | 30 s |
| **5 channels at 1%** | 4.9% | 4 | About 0.016 (one every two months) | 40 s |
| **5 channels at 2%** | 9.6% | 3 | About 2.5 | 30 s |
| **5 channels at 2%** | 9.6% | 4 | About 0.25 | 40 s |
| **3 core channels at 1%** | 3.0% | 3 | About 0.075 (one every two weeks) | 30 s |

Three conclusions follow. A strict, check-by-check AND across many channels is unusable. Grace windows rescue it at a cost of 30–40 seconds of latency, which sits in the same range as ZEBRA's 11–50-second detection times and Windows' 15-second lock debounce[47, 154]. And the result is very sensitive to each channel's error rate: doubling it from 1% to 2% multiplies lockouts by about seven at g = 3. That is why weak, conditional channels such as webcam pulse or radar heart rate must not be in the AND at all.

## Grace windows, failure domains, and the asymmetry that saves the owner

Three refinements make the arithmetic work in practice (inference). **Grace applies only to missing evidence.** A channel with no data, because the owner stopped typing, the room went dark or radar lost the chest, should decay trust slowly toward a floor, as temporal models do. A channel showing *contradictory* evidence should cut trust to zero immediately: a different face, heartbeats that disagree across sensors, keystrokes with no wrist or muscle event, or custody broken on the anchored carrier. This asymmetry defeats the ZEBRA-style attacker while sparing the idle owner, and it means the 30–40-second latency in the table never applies to an impostor swap. **Correlated failures count once.** Face match, face presence and webcam pulse share one camera and its lighting. Radar heart rate and webcam pulse both fail when the owner moves. Keystroke dynamics and wrist-to-input correlation both go quiet when the owner reads. Channels should be grouped into failure domains (camera, RF, worn sensors, input devices), and a shared-cause outage counted as one event. **Error distributions matter more than means.** Eberz et al. showed that eye-movement errors concentrate on specific users, and that optimizing mean EER can reduce security[127]. Vault should measure per-user lockout distributions and report both "time to detect an impostor" and "time to a false lockout", Mondal and Bours' ANIA and ANGA metrics[124].




**Missing evidence decays; contradiction ends it** (proposal, not a benchmark). An anchor (a hard biometric on an attested sensor) sets trust to 1. Passive refreshes, such as an attested face match, nudge it back up as it decays. Missing evidence, like an owner stepping away, only lets trust fall slowly. Contradictory evidence, like a different face, cuts it to zero at once. A vault action below the threshold makes the loop schedule a re-anchor[124, 181].

## Usability targets from the field

Measured long-session lockout data are scarce. ZEBRA's replication found no legitimate user logged out in any 10-minute sample[18]. DARPA's Active Authentication program set the reference target: the system may not "falsely reject the user more than five times in a row during continuous usage over a 40 hour period", and one system let a correct user work a regular day without a false rejection[181]. Microsoft's presence-sensing specification tolerates up to 5% false wakes and 5%

missed wakes[47]. In the only user study found, 91% of 37 participants found smartphone implicit authentication convenient and 35% were annoyed by false rejects[182]. A 2026 preprint proposes a three-zone decision (accept, reject, or inconclusive with re-verification over a shrinking window) and reports faster intrusion detection without hurting genuine users (self-reported)[183]. This research found no published multimodal desktop system reporting false-lockout rates over multi-hour sessions with ambient physiological channels included. Vault's pilots will generate the first such data.

## Verdict on "all channels must be on"

Taken literally, the founder's rule means that every channel must pass every check. That version fails three ways: the arithmetic above, Daugman's result that adding weak tests to strong ones can raise total error, and the accessibility evidence that every channel excludes somebody (Section 4). A second reading, that every channel's *hardware* must be powered and attested, fails on charging alone. A daily-charge watch drops out every day, so "watch required" means a predictable lockout.

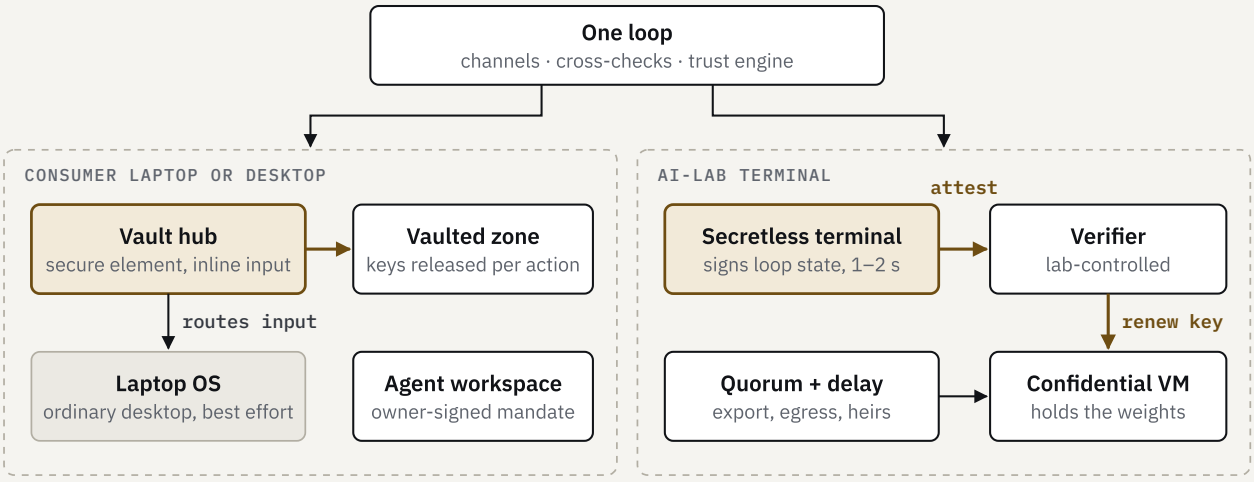
The rule survives in a stronger form that keeps its intent (proposal). **Every proposition must be covered by at least one attested channel at every moment. Every live channel holds a veto. No channel can vouch alone.** Concretely, the loop requires four things at all times. A custody carrier anchored to the owner must be attached, and there should be two overlapping carriers, such as a watch and a ring, or a band and a patch, so that charging one never breaks custody. A hard identity channel must have refreshed within its window. The input path must be attested and body-bound for any input that reaches the vaulted context. No live channel may contradict the others. Weak channels such as webcam pulse, radar, gaze and keystroke dynamics never gate on their own. They shift the operating points of the strong channels, as Daugman recommends, and they can veto by contradiction. A channel that is unavailable to a particular owner (tattooed wrist, worn fingerprints, adhesive allergy) is replaced by an equivalent bundle, not waived. In this form "all channels must be on" becomes the security property the founder intended: no single compromised or absent channel can carry the loop, and any single channel can stop it.

# Enforcement and two reference builds

## Enforcement has to live where the attacker is not

The loop's verdict is worth only as much as the component that acts on it. Five principles carry across both tiers (proposal, drawn from the threat evidence in Section 2). First, the enforcement point runs outside the general-purpose OS, because endpoint software is routinely disabled[31]. Second, authority is a short-lived key renewed only by fresh, signed loop state, so killing the loop fails closed. This is the IETF RATS watchdog pattern, in which a device lacking "regular and fresh Attestation Results" is forced into a safe state[34]. Third, the enforcement point routes input: it decides per event whether input reaches the vaulted context, the agent workspace, or nowhere. Fourth, confirmations for consequential actions are rendered by the enforcement point and answered by a secure-intent gesture, so neither malware nor an agent can produce them[28, 76]. Fifth, every sensor authenticates to the enforcement point, not to the OS[15, 74].

The signed loop state replaces the presence heartbeat. The proposal is that it carries an epoch identifier; the identity and continuity status of each custody carrier; the time and modality of the last hard-identity refresh; a summary of input-binding results since the previous epoch; any contradiction flags; and the measured boot state. It also carries a duress indicator encrypted so that only the verifier can read it. Its size and timing must not change between normal and duress epochs, so an observer cannot tell them apart (Section 9).




**Same loop, two enforcement points** (proposal). On a consumer machine, the proposed Vault hub holds the keys to the vaulted zone. It sits inline on the external keyboard, mouse and display and releases keys one action at a time. The rest of the desktop is protected only on a best-effort basis, and a laptop's built-in keyboard can't be put inline. At a lab, the terminal holds no secrets: it streams signed loop state to a verifier, and the confidential VM drops its session key the moment that stream lapses or shows a contradiction[33, 34, 76].

# Consumer reference build: commodity sensors, a Vault hub, and an honest boundary

The consumer tier has to run on laptops and desktops people already own. That forces a candid split between what commodity platforms can enforce and what they cannot.

On **macOS**, the anchors are Touch ID (built into Apple-silicon laptops or on a Magic Keyboard) and the Secure Enclave. Secure Enclave keys are used only inside the enclave "after it authorizes their use", and Keychain items can be released "only by a successful match"[184]. The custody carrier is an Apple Watch. It locks on removal, and Auto Unlock ranges the Mac within 2–3 m over peer-to-peer Wi-Fi[1, 80]. Series 11 includes the single-lead ECG that could serve a don-time same-body check, while the $249 SE 3 lacks ECG[185, 186]. Apple's ECG app has no identity function, and third-party access to the trace was not verified[93]. Two gaps remain. Macs have no Face ID, so there is no attested passive identity refresh between Touch ID presses[120]. And this research found no documented auto-lock when the Watch leaves, so Vault would add that behaviour (inference)[1].

On **Windows**, a Copilot+ laptop gives the strongest commodity identity channel. ESS face matching runs in VBS with a protected camera path, on by default, but only on built-in cameras. ESS also supports external match-on-sensor fingerprint readers[74, 119]. Windows presence sensing provides wake on approach and lock on leave on supported hardware[47]. Windows has no first-party equivalent of the Watch's ranged custody protocol. Dynamic Lock only locks, within about a minute, over Bluetooth[46]. A Windows build therefore needs a Vault-provided custody link with secure ranging, not Bluetooth presence (inference).

Commodity platforms leave three things unsolved: a ranged custody link on Windows, an attested input path, and key custody outside the OS. This report proposes a **Vault hub** for all three: a small device with its own secure element. It terminates the wearable links, so custody carriers pair to the hub rather than to the OS. It sits inline between an external keyboard, mouse and display and the computer, in the manner of ProtectIOn[76]. It signs input reports, renders confirmations, and holds the keys to the **vaulted zone**: password store, wallet keys, sensitive volume and heir policy. The hub releases those keys per action only when its own loop state holds *and* the owner gives a secure-intent gesture on the platform. This brings the lab's terminal-side secure element to the consumer at the scale of a hardware wallet. Two honest limits apply. A laptop's built-in keyboard cannot be put inline, so a laptop owner gets attested input provenance only with an external keyboard. On the built-in keyboard the loop falls back to OS provenance flags, agent-account separation and wrist binding. And on a kernel-compromised machine, the ordinary desktop outside the vaulted zone is protected only on a best-effort basis. Hub hardware, its cost and its certification are not covered by any source in this research.

| CONSUMER COMPONENT | PRODUCT AND PRICE EVIDENCE | LOOP ROLE (PROPOSAL) |
|---|---|---|
| **Custody carrier 1** | Apple Watch Series 11 from $399 (ECG); SE 3 from $249 without ECG[185, 186]; Withings ScanWatch launched at $279 with cleared ECG[187] | Anchored custody, pulse liveness, don-time ECG same-body check |
| **Custody carrier 2 (charging overlap)** | Oura Ring 4 from $349 plus $69.99 per year; Galaxy Ring $399.99[188, 189] | Second custody carrier so charging never breaks the loop; integration not verified |
| **Identity anchor and secure intent** | Built-in Touch ID or ESS face; Magic Keyboard with Touch ID about $179 at a reseller[190] | Anchoring, identity refresh, confirmation gesture |
| **Ambient presence** | Aqara FP2 mmWave sensor about $58[142] | Seat presence and second-person trigger; can only lower trust |

| CONSUMER COMPONENT | PRODUCT AND PRICE EVIDENCE | LOOP ROLE (PROPOSAL) |
|---|---|---|
| **Optional custody seal** | No security-grade patch exists; OTC CGM price anchors: Dexcom Stelo $99 for two 15-day sensors or $89 per month; Abbott Lingo $49 per 14-day sensor[191, 192] | High-assurance sessions only; custom hardware needed |
| **EMG input binding** | Meta Neural Band only in a $799 bundle with glasses; no PC pairing found[101] | Not available for v0 |
| **Vault hub** | Custom; no price evidence | Enforcement point, inline input path, vault keys |

The add-on sensor kit of watch, Touch ID keyboard and radar sensor totals about **$640**. Adding a ring brings it to about **$1,000 plus a subscription**. A maximal version built on an Apple Watch Ultra 3 (from $799) runs about **$1,050–$1,400**[185]. Many buyers already own the laptop and the watch, so Vault's marginal hardware is mostly the hub (inference from listed prices).

## AI-lab terminal build: the secretless terminal becomes the loop's body

The lab tier keeps the strongest enforcement design already available: a dedicated terminal that never holds model weights or long-lived secrets, talking to a confidential-computing environment that releases keys only on attestation. Anthropic and Pattern Labs described a design in which weights are "stored encrypted, decrypted at the loader, and never released from there", with a keyserver releasing keys only to an attested environment (vendor research)[33]. NVIDIA H100 confidential computing relies on a CPU confidential VM and is attested through NVIDIA's service[193]. Azure confidential VMs with H100 reached general availability in September 2024[194]. Fortanix sells weight release gated on composite CPU and GPU attestation (vendor claim)[195]. What changes is what the terminal attests. It no longer sends "an enrolled face is present". Every one to two seconds it sends signed loop state covering custody, identity refresh, input attribution and contradictions. The lab's verifier appraises that stream, and the keyserver drops the session key the moment it lapses or shows a contradiction (proposal)[34].

| LAB COMPONENT | V0 CHOICE (PROPOSAL) | GROUNDING |
|---|---|---|
| **Terminal** | Secretless thin client with tamper-evident chassis; trust engine and attestation key inside a FIPS 140-3 Level 3-class element that zeroizes on intrusion | Level 3 adds tamper detection and response[196] |
| **Identity anchor** | Integrated IR camera with frames signed to the secure element and randomized illumination; fingerprint or palm vein plus a FIDO authenticator; USB and virtual cameras blocked | Biometrics only with a physical authenticator[49]; injection evidence[62, 63] |
| **Custody carriers** | Enterprise band with fingerprint at don and on-body detection, plus a per-shift adhesive ECG or microneedle seal for the highest tiers | Nymi pattern (vendor)[90]; single-use seal[7] |
| **Input path** | Inline IO module in the terminal signs every HID report and renders confirmation UI over the display | ProtectIOn[76]; Not-a-Bot limits[56] |
| **Input binding** | Wrist motion per event in v0; EMG as a research track | ZEBRA lessons[18]; EMG evidence[77, 103] |
| **Ambient** | Radar occupancy and second-person detection; optional verified co-presence of a second operator | RAND SL5 "supervised access"[68] |

| LAB COMPONENT | V0 CHOICE (PROPOSAL) | GROUNDING |
|---|---|---|
| **Relying party** | Confidential VM or keyserver holding a seconds-scale session key; composite CPU and GPU appraisal | Watchdog[34]; TEE.fail forged attestations with a sub-$1,000 interposer[197] |
| **Agents** | Agent workloads under distinct identities and mandates; no mandate can grant egress | Windows agent-account model[27]; NIST NCCoE[176] |
| **Irreversible actions** | K-of-N biometric-bound quorum plus time delay for export, new egress, quorum or heir changes | Two-person control[198]; RAND SL3[68] |

Mapped onto RAND's access benchmarks, per-input attribution exceeds the SL2 requirement of FIDO authentication "for every interaction" or after about 60 seconds[68]. Hardware-rooted enforcement addresses SL4's "secure hardware required for access", and co-presence mode is Vault's contribution to SL5's "supervised access for everyone" inside facility controls[68, 199]. The residual risks remain. The terminal still displays outputs. TEE.fail showed that server attestations can be forged with physical access. NVIDIA GPU reports were not bound to a specific confidential VM, so the verifier must appraise CPU and GPU evidence as one composite[197]. Reference prices exist only for parts: a five-band Nymi starter kit is listed at $1,099 (third-party listing)[200], and a PalmSecure sensor at about $325 from a reseller[201]. Terminal cost, and the cost and schedule of FIPS validation, were not found.

## What each build can and cannot promise

| THREAT | CONSUMER BUILD | LAB BUILD |
|---|---|---|
| **Handover after login** | Defeated: custody break or new face ends authority at once | Defeated, plus co-presence option |
| **Owner's agent overreaching** | Contained in agent workspace; vaulted zone needs owner secure intent | Agent identities cannot reach egress; quorum for agent-initiated export |
| **Injected USB device** | Defeated for external peripherals behind the hub; built-in laptop keyboard relies on OS flags | Defeated: only the inline IO module's signed reports count |
| **Virtual-camera deepfake** | Defeated on Windows ESS; on macOS the camera can only lower trust | Defeated: signed frames on an integrated camera |
| **Kernel or admin compromise** | Vaulted zone protected by hub and secure element; ordinary desktop best effort | Weights never on terminal; session fails closed |
| **Proximity relay** | Custody plus secure ranging; Bluetooth presence never counts | Same, inside facility controls |
| **Coercion** | Not detected; covert signal, decoy and delays on vault actions | Not detected; covert signal, quorum, delay, quarantined egress |

# Signal it, shadow it, and make it pay nothing

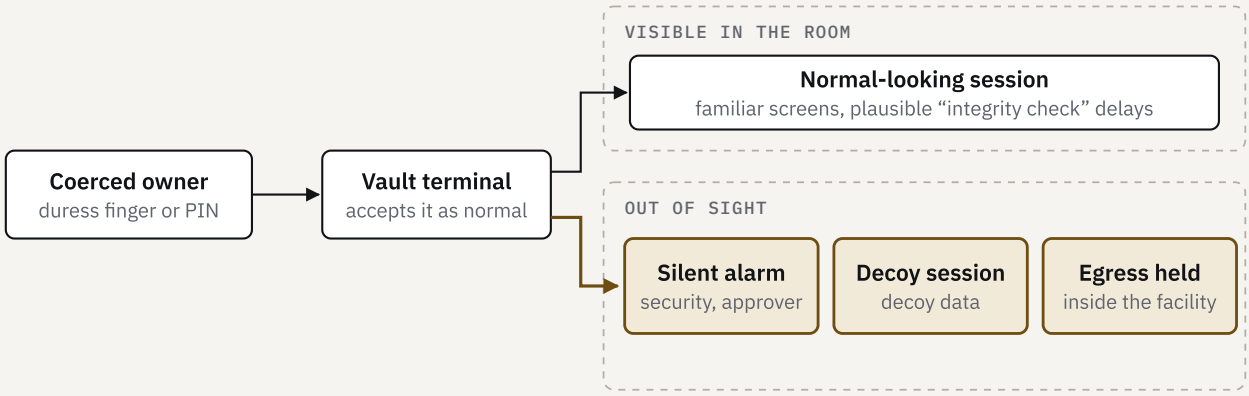
## The loop cannot detect coercion, and it raises the stakes

A coerced owner satisfies the first three propositions. The body is alive and attached, it is the enrolled person, and the inputs genuinely come from its hands. No arrangement of channels changes that. The deception-detection literature explains why the fourth proposition cannot be measured instead. The benchmark lab stress classifier reached 93% binary accuracy on 15 mostly young male subjects wearing a chest strap[35]. Field performance drops sharply: one smartwatch study saw F1 fall from 0.84 to 0.71[202], and in a government in-the-wild program no team met its targets[36]. No dataset covers real coercion. Base rates finish the argument. Fifty operators opening four sessions a day produce about 73,000 sessions a year. With genuine duress once a decade, a detector with 95% sensitivity and a 1% false-positive rate raises about 730 false alarms a year (this research's own arithmetic, framed by the National Academies' polygraph analysis and Axelsson's base-rate fallacy)[78, 203]. For EU employees, inferring stress from biometrics is presumptively prohibited when the purpose is protecting property. The Commission's guidelines give "measuring anxiety based on measured stress levels" as their own prohibited example[37].

The loop also raises the stakes. A computer that only one living body can operate makes that body the target, and attackers increasingly go after families: CertiK reports family members of crypto victims increasingly targeted in 2026[69]. The loop does remove two incentives (inference). Liveness and per-event input binding mean that an incapacitated or dead owner, or a stolen device, is worthless to an attacker. They do nothing against a conscious owner held at gunpoint.

## What the loop adds: more covert signals and a shadow mode

The loop's channels give the owner more ways to signal duress covertly than a login screen does (proposal). A **duress finger** enrolled on Touch ID or ESS fingerprint behaves normally while raising the alarm, as access-control products already offer[204]. A **duress PIN** opens a working decoy, as Coldcard's trick PINs open a decoy wallet where "nothing special is shown on the screen"[39]. A **duress gesture** could be read by an EMG band, such as a specific muscle pattern with little visible movement. That last idea is attractive because an observer cannot see it, but it is untested: no source evaluates covert EMG signalling or its false-trigger rate under stress, and the FTC's concern that victims "fumble" emergency PINs applies with full force[205]. Whatever the surface, the loop must answer with an **indistinguishable shadow state**. Clark and Hengartner set the formal requirement: the duress credential must be "indistinguishable" by the attacker, any lockout must be "invariant to the type of the passwords being entered", and a visible lockout invites "threatening retaliation"[38]. Decoys must be internally consistent, since operating systems once leaked evidence of TrueCrypt hidden volumes[206]. GrapheneOS's irreversible duress wipe is the wrong default for an owner held by an attacker who expects success[207].




**Signal explicitly, degrade silently** (proposal). An explicit duress signal never produces a visible lockout or wipe, because those can get a coerced person hurt. The session looks normal while security contacts or the remote approver are alerted, a decoy environment takes over (a decoy wallet on a consumer machine, watermarked canary weights at a lab), and all egress is quarantined inside the facility. A watching attacker can't tell that the signal was given[38, 39, 205].

## Make coercion unprofitable on both tiers

The strongest lesson from vault locks, pharmacies and self-custody is to **remove the payoff rather than detect the threat**. Toronto police reported an 82% drop in pharmacy robberies in 2024 after time-delay safes[208]. British Columbia's standards were reported to have cut pharmacy robberies by 94%, and a Calgary detective said time-delay safes "do not lead to an escalation of violence"[40]. These are uncontrolled before-and-after comparisons and a police assertion, not studies. The US Air Force's two-person concept ensures "a lone individual cannot perform an incorrect act or unauthorized procedure"[198]. Bitcoin covenant "vaults" add a window in which a recovery key can claw back a theft[209].

| TRIGGER | CONSUMER RESPONSE (PROPOSAL) | LAB RESPONSE (PROPOSAL) | GROUNDING |
|---|---|---|---|
| **Any irreversible action, always** | Large transfers and heir or policy changes need a delay plus a co-signer (custodian, family member, security firm); the delay is publicized so "I can't" is credible | Export, new egress and quorum changes need a K-of-N live quorum plus delay | Time delays[40]; two-person control[198] |
| **Explicit duress signal (finger, PIN, gesture)** | Shadow state: decoy vault opens, alarms go silently to chosen contacts or a protection firm, real keys stay sealed | Shadow state: canary environment, honeytoken credentials, egress quarantined, silent alarm to security and the remote approver | Indistinguishability[38]; decoy wallets[39]; honeywords[210] |
| **Second face or a hand on the owner plus an out-of-scope action** | Friction ladder: longer delay, then remote re-confirmation | Friction ladder ending in a two-person requirement; scope shrinks toward read-only | Base rates[203] |
| **Physiological stress features** | Not computed; physiology used only for liveness and binding | Not computed; presumptively prohibited for EU staff | [35, 37] |

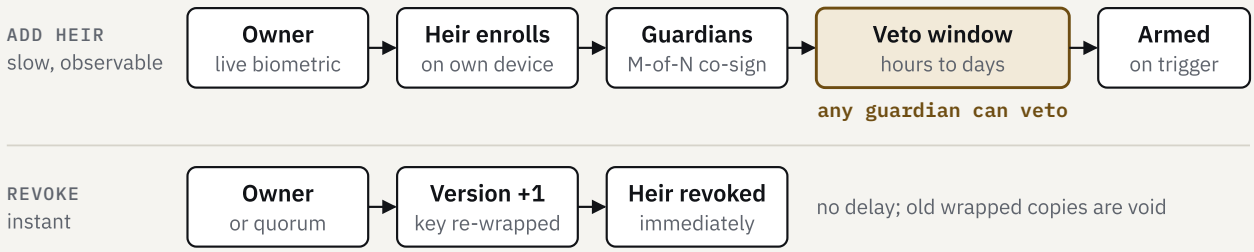
Three practices complete the design (proposal, carried from the duress evidence). Remote approvers and consumer co-signers need their own out-of-band duress channel and should be trained to *appear* to approve while escalating. Coercion often happens at home, so a duress alert should trigger a check on the family. Irish "tiger kidnapping" protocols, which put hostages' safe return first, show why (partially verified parliamentary record)[211]. Any switch the coerced owner can operate alone, such as 1Password's Travel Mode, which removes vaults from a device, is itself a coercion target[212]. Restoring full access after a duress event must therefore need something the owner alone cannot do.

# The loop enrolls a new owner, it never lets an heir pass as the old one

## Heirs cannot pass the owner's loop, and should not try

An heir is a different body. No arrangement of the loop's channels can make an heir satisfy "this is the enrolled owner" without diluting that proposition for everyone. Succession is therefore a ceremony that *converts* the Vault to a new owner and starts a new loop around a new anchored body. The research found no product binding owner-authorized biometric heirs to hardware, and every shipping inheritance product pairs cryptography with a waiting period and a human or legal attestation[85, 213, 214]. The design below is proposal throughout.

**Designation** is an owner-signed delegation generated inside the owner's secure element. It binds the heir's device-bound public key to a policy covering activation conditions, scope and expiry. The heir's templates are enrolled on the heir's own hardware and never exported, in line with the EDPB's view that templates on the individual's own device are "in principle compatible" with the GDPR[215]. **Adding an heir** is the most dangerous operation in the system. It needs a live owner loop in normal state, live enrollment of the heir, guardian co-signatures, and a delay of hours to days during which any guardian can veto. **Revocation** is the mirror image: instant for the owner, quorum-only when the owner is unavailable. A coerced owner can be forced to *start* an addition but cannot *complete* it before others intervene. Apple's Stolen Device Protection applies the same asymmetry, requiring biometrics, a one-hour delay and biometrics again before a recovery contact can be changed away from familiar places[3]. A duress signal during "add heir" should make the ceremony appear to succeed while silently freezing it.




**Asymmetric delays** (proposal). Adding an heir is the most dangerous operation in the system, so it is slow and observable: live owner, live heir on the heir's own hardware, a guardian quorum, then a veto window. Revoking is instant. A coerced owner can start an addition but can't complete it before guardians can step in. A duress signal during the ceremony makes it appear to succeed while silently freezing it[3, 213, 223].

## The loop contributes a high-quality owner-liveness signal

The loop does add one thing to succession. It produces the best available evidence that the owner is alive and active, and that evidence can hold the heir path closed. Liana's Bitcoin wallet uses this pattern: the owner periodically "refreshes" coins to keep the heir's relative timelock from opening[216, 217]. In Vault, each normal-state owner epoch could advance a

monotonic last-seen counter inside the secure element. The heir path becomes armable only after N days without owner presence *and* trustee attestation of death, incapacity or departure. Storing only the counter, not a presence history, keeps the succession signal from becoming surveillance (proposal). Absence is not death. Travel, hospitalization and a lost wearable all look like silence, so the timer must be long and the trustee attestation mandatory. Casa's inheritance uses a six-month window the living owner can cancel[85].

Agents need an explicit rule at succession (proposal). When the heir path activates, every mandate the owner signed for an agent should be revoked. An heir who wants agents signs new mandates under the new loop. Otherwise an owner's long-running agent could keep acting for months on behalf of a principal who no longer exists.

## Blood, DNA and kinship do not belong in the gate

A kinship or DNA gate fails on every axis. Rapid DNA takes about 90 minutes[6]. DNA transfers to other people's hands in 50% of trials[21]. Half-siblings showed 5–7% false inclusion or exclusion even at 40 STR loci[113]. US employers with 15 or more employees may not request genetic information about an employee or a family member[218], and genetic data is special-category data under the GDPR[219]. Heirs should be authorized by the owner, not identified by biology. A supervised in-person enrollment ceremony provides everything a blood draw would, without the drawbacks.

| SUCCESSION ELEMENT | CONSUMER PATTERN | LAB PATTERN |
|---|---|---|
| **Who succeeds** | Named heirs with their own Vault enrollment | Pre-approved successor operators; IANA's Root KSK Ceremony 13 replaced a Crypto Officer[220] |
| **Guardians** | Family, lawyer, custodian; Casa-style co-signer[85] | M-of-N custodians; AWS CloudHSM quorum of 2–8 approvers with 10-minute tokens[221] |
| **Activation** | Long loop-silence timer plus trustee attestation; Google Inactive Account Manager pattern[222] | Leaver trigger plus custodian attestation |
| **Recovery without biometrics** | Sealed paper kit split SLIP-39-style across groups[223] | Sealed, alarmed break-glass accounts in separate safes, validated every 90 days[224] |
| **Highest tier** | Optional "no heirs" mode for owners who prefer destruction | "Irrecoverable key policy" at SL5: re-key under a fresh quorum rather than inherit[68] |
| **Agents** | All mandates revoked at activation | Agent identities re-issued under successor operators |

# Verification is defensible on both tiers, inference is the liability

A continuous loop collects far more than a login does: face and fingerprint templates, but also heart signals, muscle activity, typing rhythm, possibly glucose, and observations of everyone else in the room. The legal exposure follows the streams more than the purpose.

## Consumer tier: the behavioural and physiological streams carry the heaviest load

For a US consumer product, the two sharpest risks are statutes with private rights of action. Illinois' BIPA requires a written release before collecting biometric identifiers. A 2024 amendment made repeated collection from one person by one method a single violation and allowed electronic signatures[225], and the Seventh Circuit held in April 2026 that the amendment applies retroactively[226]. On-device processing has not been a safe harbor. In *Hazlitt v. Apple*, a case over on-device face clustering in Photos, the court held that BIPA "possession" can apply even where the company does not exclusively control data stored on users' devices[227]. The class was certified on 5 June 2026[228]. Press reports that the Seventh Circuit denied Apple's interlocutory appeal, with exposure estimates of $6.5–32.5 billion (secondary)[229]. An earlier Illinois appellate decision, *Barnett v. Apple*, dismissed claims over biometrics stored only on-device[230]. The case law therefore points both ways, and no court has ruled on on-device *verification*.

Washington's My Health My Data Act is the statute most directly aimed at a loop. "Consumer health data" includes "bodily functions, vital signs, symptoms, or measurements" and biometric data. Biometric data expressly includes "keystroke patterns or rhythms and gait patterns or rhythms that contain identifying information". "Collect" covers anything that will "access, retain, receive, acquire, infer, derive, or otherwise process" such data[42]. Violations are enforceable by the attorney general "as well as through private action"[231], and the first class action was filed against Amazon in 2025[232]. Health *inferences* are in scope, and typing reveals health. Keystroke hold-time features distinguished early Parkinson's patients from controls[233]. A loop's behavioural template drifting with a tremor is therefore itself a health inference. It must never be surfaced, stored or exported (inference). Nevada's similar law is narrower and has no private right of action, and Connecticut now requires consent for consumer health data[234]. Texas's CUBI has no private right, but its attorney general obtained $1.4 billion from Meta and, per legal trade press, $1.375 billion from Google[235, 236].

Federal law adds the FTC. Its 2023 policy statement treats unsubstantiated claims about biometric accuracy as deceptive, and covert collection or failure to assess foreseeable harms as unfair[237]. The Rite Aid order shows the remedy: a five-year ban on facial-recognition surveillance after "thousands of false-positive matches"[238]. The amended Health Breach Notification Rule covers health apps and connected devices outside HIPAA, counts unauthorized disclosure as a breach, and carries penalties up to $51,744 per violation[239]. That matters if Vault ever syncs a heart-rate or glucose stream. The amended COPPA Rule treats children's biometric identifiers, including gait patterns and facial templates, as personal information, with compliance required from 22 April 2026[240].

The EU picture favours the core function. The AI Act's Recital 17 distinguishes biometric *verification*, "including unlocking a device", from remote biometric identification as having "a minor impact on fundamental rights"[241]. An owner's purely personal processing likely falls within the GDPR's household exemption[242]. Whether a device maker is a controller when processing stays local is unsettled. Academics argue that edge processing does not automatically take manufacturers out of scope[243]. Any emotion recognition or biometric categorisation triggers Article 50(3)'s duty to inform, from 2 August 2026[244], and stand-alone high-risk obligations move to 2 December 2027[245].

Two consumer edge cases need product decisions (proposal). The first is bystanders. A loop that watches the room with a camera or radar is processing a spouse's or child's data. Second-person detection should therefore establish only "another person is present", without identifying or retaining anything, and children should receive no camera processing beyond presence. The second is the microneedle channel. A glucose stream is health data in the plainest sense, so the seal should report only "attached and physiologically plausible" to the enforcement point, never readings.

## Lab tier: the AI Act bans the tempting feature, and employment law shapes the rest

For lab operators in the EU, the decisive rule is Article 5(1)(f), which prohibits inferring emotions in the workplace except for medical or safety reasons. It has applied since 2 February 2025[246, 247]. The Commission's guidelines list keystrokes, heartbeats and ECG among in-scope signals. They state that "the general monitoring of stress levels at the workplace is not permitted", and they read the safety exception as protecting life and health, "not … property against theft or fraud"[37]. A lab loop that computed stress from its ECG, PPG or EMG streams to detect duress would protect model weights, which are property, and would very likely be prohibited (inference). Verification against a template stored on a device "for the sole purpose of … unlocking a device, or having security access to premises" sits outside the remote-identification ban[37]. Annex III excludes sole-purpose verification from high-risk identification[248]. No guidance addresses *continuous, passive* re-verification, which involves less active participation than a one-time unlock. That is an open question for counsel.

Under the GDPR, employee consent is presumptively invalid[249], so labs need a national legal basis and a necessity case. The Dutch implementing act permits biometrics "necessary for authentication or security purposes". Its explanatory memorandum contrasts a nuclear power plant, where they are likely justified, with a car garage[250]. Enforcement so far has hit time-and-attendance uses: a €725,000 Dutch fine and a €45,000 Belgian one[251, 252]. France's CNIL prefers templates under the person's exclusive control[253]. The EDPB found templates held on the individual's own device "in principle compatible" with the GDPR[215]. A proposed Article 9(2)(l) exception for verification under the data subject's "sole control" was welcomed by the EDPB and EDPS but was still a proposal at last check[254]. In the US, Colorado lets employers require biometric consent to access secure hardware and software, but not for tracking time spent in an application[255]. Washington exempts biometrics collected "in furtherance of a security purpose"[256]. New York bars employers from requiring fingerprints[257]. California requires risk assessments for sensitive personal information from 1 January 2026[258]. At least a dozen states bar employer-required implants[111], and GINA rules out genetic gates[218].

| LOOP DATA STREAM | CONSUMER LEGAL HOOK | LAB LEGAL HOOK | DESIGN RESPONSE (PROPOSAL) |
|---|---|---|---|
| **Face and fingerprint templates** | BIPA release; CUBI; GDPR Art. 9 with household exemption for the owner[225, 242] | GDPR Art. 9 necessity; EDPB on-device position; NY fingerprint rule[215, 257] | Templates only in the owner's secure element; e-signed release at enrollment |
| **Heart signals (ECG, PPG, HRV)** | MHMDA "vital signs"; HBNR if disclosed[42, 239] | GDPR health data; AI Act in-scope signal[37] | Used only for liveness and coherence; never stored as a series or exported |
| **Keystroke rhythm, gait, EMG** | MHMDA biometric data; COPPA for children[42, 240] | AI Act in-scope signal; Colorado anti-tracking[255] | Per-event binding verdicts only; no behavioural profile leaves the enforcement point |
| **Glucose or interstitial chemistry** | Health data under MHMDA and HBNR | GDPR health data | Seal reports only "attached and plausible" |
| **Stress or emotion inference** | Art. 50(3) notice in the EU; MHMDA health inference[244] | Presumptively prohibited under Art. 5(1)(f)[37] | Not computed on either tier |

| LOOP DATA STREAM | CONSUMER LEGAL HOOK | LAB LEGAL HOOK | DESIGN RESPONSE (PROPOSAL) |
|---|---|---|---|
| **Bystanders in the room** | BIPA, MHMDA and COPPA exposure for non-consenting people | Works-council and notice duties; NY monitoring notice[259] | Presence-only detection with no identification or retention |
| **Presence and attribution logs** | FTC unfairness if covert[237] | Function creep toward productivity surveillance[255, 260] | Security events only; succession uses a counter, not a history |

# Two tiers, one architecture, very different buyers

## Consumer tier: high-risk individuals who already pay for security services

Consumer demand is rising, though concentrated. CertiK counted 72 verified crypto wrench attacks in 2025, up 75%, with more than $40.9 million in confirmed losses and Europe accounting for over 40%[41]. Among S&P 500 companies, CEO personal-security perks rose from 35% to 54% prevalence in one year, other named executives' security spending rose from a median of about $10,000 to $32,000, and 2026 proxies increasingly list "digital executive protection"[261]. US border device searches hit a record of about 55,000 in FY2025 (secondary)[262]. Closer to home, an estimated 20% of US adults snooped on someone else's phone in a year[50]. Wearable ownership skews affluent: 31% in households earning $75,000 or more, against 21% overall[143].

Adjacent products show what this group pays for. Casa's custody-and-inheritance plans run from $250 to $7,500 a year, with inheritance included in every individual plan (vendor pricing)[263]. BlackCloak's executive digital-protection plans reportedly cost $3,000–7,000 a year (third-party listing)[264]. Purism sells a $1,999 "Made in USA" phone[265]. The cautionary case is standalone secure hardware. Sirin Labs' $999 Finney phone sold poorly enough that the company laid off about a quarter of its staff in 2019 (secondary)[266]. Free platform features also set a baseline consumers expect without paying: Stolen Device Protection, Identity Check and inactivity reboots[3, 8, 267]. This research infers price anchors of about $10–25 a month for self-serve software on owned hardware, and $2,000–7,500 a year for a high-risk tier with hub, setup, duress protocols and succession. It also infers that the best channels are businesses that already sell security as a recurring service and already hold the succession relationship: crypto custodians, executive-protection firms and family offices. To earn its price, consumer Vault must sell what the free features do not offer: continuous identity rather than custody, coverage of the desktop, duress handling, heir enrollment, and containment of the owner's own agents.

## Lab tier: a dozen buyers, rising mandates and an empty intersection

The core lab market is tiny and high-value. Epoch AI counted more than 30 models above 10^25 FLOP from 12 developers as of June 2025[43]. US government pre-deployment testing agreements covered five frontier labs in May 2026 (secondary)[268]. The second ring includes hyperscalers and inference providers that hold partner weights, plus government AI data centers. Mandates create demand without requiring biometrics. California's SB 53 requires frontier developers to publish frameworks for securing unreleased weights, with penalties up to $1 million per violation (law-firm summary)[269]. New York's RAISE Act takes effect on 1 January 2027[270]. The EU code of practice for general-purpose AI asks for "restrictions on device and account sharing" and "periodic personnel integrity testing" (unofficial mirror of the final text)[271]. Lab frameworks still leave the human unverified. Anthropic's ASL-3 protections include "two-party authorization for model weight access" but place sophisticated insider risk out of scope[4]. OpenAI requires hardware-backed security and multi-person approval[5]. The Frontier Model Forum recommends quorum operations and no "static or persistent credentials"[10]. Irregular, the closest comparable company, raised $80 million in September 2025 selling security work to a handful of frontier labs[272].

| PRODUCT | TIER | WHAT IT DOES | WHAT IT LACKS FOR A LOOP |
|---|---|---|---|
| **Apple SDP, Android Identity Check, Auto Unlock**[1, 3, 8] | Consumer | Custody and episodic identity, free | Continuous identity, desktop input provenance, duress, heirs |

| PRODUCT | TIER | WHAT IT DOES | WHAT IT LACKS FOR A LOOP |
|---|---|---|---|
| **Casa, BlackCloak**[263, 264] | Consumer | Custody with inheritance; executive digital protection | Any verification loop; natural channel partners |
| **Teleport**[273] | Lab | Per-session MFA, hardware keys, dual authorization, moderated sessions | A continuously verified human |
| **CyberArk / Palo Alto Networks**[274, 275] | Lab | PAM leader, acquired for about $25 billion | No continuous biometric binding found; has distribution to add it |
| **Okta Identity Threat Protection**[276] | Lab | Continuous session-risk re-evaluation | Hardware-attested human |
| **Plurilock**[12] | Both | Keystroke and mouse checks "every 3–5 seconds" (vendor claim) | Strong identity; attested input |
| **Nymi Band**[90] | Lab-adjacent | Fingerprint band, FIDO2, on-body custody | Presence at the keyboard; input binding |
| **HYPR plus YubiKey Bio**[277] | Lab | Fingerprint FIDO authenticator | Continuity |
| **Fortanix Confidential AI**[195] | Lab | Attestation-gated weight release (vendor claim) | Any human attestation; likely partner |
| **Windows agent accounts; World AgentKit**[27, 169] | Both | Agent identity and human backing | Local per-input attribution |

Agent identity is the new hook for both tiers. NIST's NCCoE, the OpenID Foundation and the payment networks are all now asking how to tell a human's action from an agent's[29, 176, 278]. A loop that attributes every input to the owner, the owner's agent or nobody answers that question at the device. Neither the PAM vendors nor the consumer platforms have staked out that position (inference).

# One prototype per tier, then the research the loop still needs

## One loop, two prototypes, measurable pass marks

Both prototypes should run the same loop software against different enforcement points. The acceptance criteria below are proposals derived from the evidence, not established benchmarks.

| WORKSTREAM | CONSUMER PROTOTYPE | LAB PROTOTYPE | PROPOSED ACCEPTANCE CRITERION |
|---|---|---|---|
| **Loop core** | macOS with Apple Watch and Touch ID keyboard; Windows Copilot+ variant with ESS face; hub prototype inline on desktop peripherals | Secretless terminal streaming signed loop state to a confidential H100 VM holding encrypted mock weights | Authority ends within one epoch (≤2 s) of a contradiction; no plaintext secrets outside the enforcement point |
| **Usability** | Ten owners over four weeks, including tattooed, older and adhesive-sensitive users on substitution bundles | Operator pilot over full 40-hour weeks | No more than 5 consecutive false rejects per 40 h[181]; report per-user lockout distributions, not means[127] |
| **Handover and impostor swap** | Second person sits down mid-session | Same, plus lent-band and lent-card tests | Swap ends authority on first contradiction; lent carriers go dead on removal |
| **Injection** | Rubber Ducky and O.MG-class devices on hub ports; virtual camera on Windows | Virtual-HID driver on host; USB and virtual cameras; IR-frame injection | No injected input reaches the vaulted context; every synthetic event attributed or blocked |
| **Cross-modal forgery** | Real-time face swap with attacker wearing an unanchored band | Same, plus radar actuator replay and ZEBRA-style opportunistic mimicry | Agreement among attacker-controlled channels earns no trust; mimicry acceptance well below ZEBRA's 40%[19] |
| **Agents** | Desktop agent in an agent workspace attempts vaulted actions | Operations agent attempts weight egress | Zero vaulted or egress actions without owner-present secure intent or quorum |
| **Duress** | Duress finger and PIN; decoy vault; silent alert to a contact | Duress signal; canary environment; quarantined egress | Red team iterating across sessions cannot distinguish shadow from normal[38] |
| **Succession** | Add-heir ceremony with veto window; loop-silence timer | Successor-operator drill; break-glass drill | A coerced owner can start but not complete an heir addition; revocation is instant |
| **Privacy** | No raw biometric or physiological signal leaves the device or hub | Same; EU configuration disables all inference | Reviewed by counsel against BIPA, MHMDA, GDPR and Art. 5(1)(f) |

## Ten open questions decide whether the loop is buildable

| OPEN QUESTION | WHY IT MATTERS | HOW TO RESOLVE |
|---|---|---|
| **Can EMG or wrist motion attribute individual keystrokes reliably, and resist attack?** | P3 has no validated channel; no paper tests EMG-to-keystroke attribution as security | Phase 2 study on open sEMG hardware and Meta's public dataset[279] |
| **Is the ECG-to-facial-pulse delay stable enough to catch forged video?** | Rule 8 depends on it; no tolerance found | Bench study with ECG patch and attested camera |
| **How fast does a microneedle or CGM sensor report removal, and can it be fooled in solution?** | Decides whether the seal is a seal | Vendor partnership or custom sensor |
| **Can ESS face, or any secure-element path, re-verify continuously through a supported API?** | Decides whether passive identity refresh is hardware-rooted on consumer machines | Microsoft engagement; prototype |
| **What does an inline hub cost and how is it certified?** | Consumer enforcement and P3 depend on it | Hardware spike; FIPS and Common Criteria quotes |
| **What false-lockout rates do multi-hour sessions with ambient channels produce?** | No published data exist | Both pilots |
| **Is on-device continuous verification "collection" under BIPA and MHMDA, and inside the AI Act's verification carve-out?** | Sets consent design and EU exposure | Counsel; DPA consultation |
| **Can owners perform covert duress gestures reliably under fear?** | No field data for any duress signal[205] | Rehearsal studies; red-team exercises |
| **Will a standard emerge for per-event agent attribution on the OS?** | Windows separates agents by account, not by event | Track NCCoE, Web Bot Auth and Windows agent work[174, 176] |
| **Are GPU attestations now bound to a specific confidential VM after TEE.fail?** | Prevents borrowed attestations at the lab keyserver[197] | Vendor engagement; composite-appraisal testing |

## Phase 2 proves the loop end to end and leaves inference out

Phase 2 should deliver the two prototypes above, a hub hardware spike, and three research tracks: per-event EMG and motion input binding, the pulse-transit timing check, and microneedle-seal removal detection. Each should be evaluated against the attacks that broke earlier systems (ZEBRA mimicry, ECG injection, heartbeat-preserving deepfakes), not only against naive impostors. Out of scope for Phase 2: physiological or voice duress inference, DNA or kinship gates for heirs, keys derived from biometrics, mandatory implants or patches, per-key fingerprint keyboards, and SL5 facility controls.

The evidence changes what "only its owner can use it" should mean. Recognizing the owner at the door is a solved problem, and at that point the problem has barely begun. What matters is whether each input is explained by the owner's living body, whether the owner's agents stay inside the authority the owner signed, and whether an owner who is present but not free can be stopped from delivering the payoff alone. A loop built on those three answers turns the founder's two instincts into sound engineering. Every channel stays on in the sense that every channel can stop the machine. And the body's chemistry serves the role it can actually play, as a seal of continuous custody rather than a name.

# Sources


1. Apple Platform Security, "Automatically unlock Apple devices". *Vendor documentation.*
2. Google Android Help, "Let your Android device stay unlocked" (Extend Unlock). *Vendor documentation.*
3. Apple Support 120340, "About Stolen Device Protection for iPhone". *Vendor documentation.*
4. Anthropic, "Activating AI Safety Level 3 Protections" (May 2025). *Lab primary source.*
5. OpenAI, Preparedness Framework v2 (Apr 2025). *Lab primary source.*
6. BioSpace / Thermo Fisher, "FBI approves Thermo Fisher Scientific's Rapid DNA solution for law enforcement booking stations". *Vendor press release.*
7. FDA, De Novo DEN240080 decision summary (Biolinq Shine). *Regulatory record.*
8. Google, "Android theft protection: Identity Check and expanded features" (Jan 2025). *Vendor announcement.*
9. Pharmaceutical Technology, "The Nymi Connected Worker Platform: how does it work?". *Sponsored content (vendor claim).*
10. Frontier Model Forum, "Foundational Security Practices" issue brief (July 2024). *Industry body.*
11. SecureAuth documentation, "Continuous facial authentication" (SessionGuardian). *Vendor documentation / claim.*
12. Plurilock, "Behavioral biometrics: the science". *Vendor claim.*
13. Alecci et al., "What the Heart Can(not) Tell" (Sensors, 2025). *Peer-reviewed.*
14. Eberz et al., "Broken Hearted: How To Attack ECG Biometrics" (NDSS 2017). *Peer-reviewed.*
15. Apple Platform Security, "Magic Keyboard with Touch ID". *Vendor documentation.*
16. Seibold et al., "High-quality deepfakes have a heart!" (Frontiers in Imaging, 2025). *Peer-reviewed.*
17. Chen, Liao, Wu, "PulseEdit: editing physiological signals in facial videos" (IEEE TIFS 2022), Authorea. *Peer-reviewed (preprint version).*
18. Huhta et al., "Pitfalls in Designing Zero-Effort Deauthentication: Opportunistic Human Observation Attacks" (NDSS 2016, arXiv 1505.05779). *Peer-reviewed (preprint version).*
19. Aalto University, "Is zero-effort computer security a dream?". *University release on research.*
20. John Daugman, "Combining Multiple Biometrics". *Academic note.*
21. UNH Today, touch-DNA transfer study (Mar 2024). *University release on research.*
22. Metabotype conservation and individual identification in the KORA cohort (Metabolomics, 2014). *Peer-reviewed.*
23. Dexcom provider education, "Dexcom G7 app: how to replace your sensor". *Vendor documentation.*
24. Microsoft Learn, "Virtual HID Framework (VHF)". *Vendor documentation.*
25. O.MG, product site. *Vendor claim.*
26. Claude Code documentation, "Computer use". *Vendor documentation.*
27. Microsoft Learn, Windows 11 security book: "Agentic security". *Vendor documentation.*
28. Apple Platform Security, "Secure intent and connections to the Secure Enclave". *Vendor documentation.*
29. Google Cloud, "Announcing Agent Payments Protocol (AP2)" (Sept 2025). *Vendor announcement.*
30. IETF RFC 8693, "OAuth 2.0 Token Exchange". *Standards document.*
31. SentinelOne, "Bring Your Own Vulnerable Driver: How EDR Killing Became an Industry". *Vendor incident-response data.*

32. The Register, "Windows Hello, hell no" (ERNW at Black Hat 2025). *News coverage of security research.*
33. Anthropic with Pattern Labs, "Confidential Inference via Trusted Virtual Machines" (June 2025). *Vendor research design.*
34. IETF RFC 9334, "Remote ATtestation procedureS (RATS) Architecture". *Standards document (Informational).*
35. Schmidt et al., "Introducing WESAD" (ICMI 2018). *Peer-reviewed (lab study).*
36. D'Mello & Booth, "Affect detection from wearables in the wild". *Academic paper on a government field program.*
37. European Commission, Guidelines on prohibited AI practices under the AI Act, C(2025) 5052 final (July 2025). *Official, non-binding guidance.*
38. Clark & Hengartner, "Panic Passwords: Authenticating under Duress" (USENIX HotSec 2008). *Peer-reviewed.*
39. Coinkite, Coldcard documentation: "Trick PINs". *Vendor documentation.*
40. Alberta College of Pharmacy, "An effective deterrent" (Jan 2022). *Professional regulator article (reported, uncontrolled figures).*
41. Decrypt, "$41M in losses as crypto wrench attacks hit record high in 2025" (CertiK data). *News coverage of industry data.*
42. Revised Code of Washington 19.373.010 (My Health My Data Act definitions). *Statute.*
43. Epoch AI, "Models over 10^25 FLOP". *Research data.*
44. Android Central, "Smart Lock on-body detection". *Trade press.*
45. 9to5Google, Android Smart Lock on-body detection bug (Mar 2019). *Trade press (secondary).*
46. PCWorld, "This Windows security trick auto-locks your PC when you leave" (Sept 2026). *Trade press.*
47. Microsoft Learn, "Presence sensing: wake on approach and lock on leave". *Vendor documentation and OEM specification.*
48. Microsoft Learn, "Continuous access evaluation". *Vendor documentation.*
49. NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management. *Government standard.*
50. Marques et al., "Snooping on mobile phones: prevalence and trends" (SOUPS 2016). *Peer-reviewed.*
51. CBS News San Francisco, coverage of charges against Linwei Ding. *Secondary news coverage (allegation).*
52. US Department of Justice, "Former Google engineer found guilty of economic espionage and theft of confidential AI technology" (Jan 2026). *Government press release.*
53. OpenAI, "Introducing Operator" (Jan 2025). *Vendor announcement (read via search excerpt).*
54. Google, "Introducing the Gemini 2.5 Computer Use model" (Oct 2025). *Vendor announcement.*
55. Plesner, Vontobel, Wattenhofer, "Breaking reCAPTCHAv2" (arXiv 2409.08831, 2024). *Academic preprint.*
56. Gummadi et al., "Not-a-Bot: Improving Service Availability in the Face of Botnet Attacks" (NSDI 2009). *Peer-reviewed.*
57. Microsoft Learn, KBDLLHOOKSTRUCT. *Vendor documentation.*
58. Apple Developer Forums, thread 789896 (PostEvent and Accessibility privileges). *Vendor engineer forum answer.*
59. Pasquale Pillitteri, "Rubber Ducky and O.MG Cable guide 2026". *Secondary (blog guide).*
60. Patrick Wardle, "Synthetic Reality" (Objective-See, Aug 2018). *Security research.*
61. Microsoft Learn, sas.h (SendSAS). *Vendor documentation.*
62. iProov, Threat Intelligence Report 2025 (press release). *Vendor threat data.*
63. The Record, "Windows Hello bypassed using infrared image" (CyberArk, CVE-2021-34466). *News coverage of security research.*
64. SecurityWeek, "Windows Hello face recognition tricked with photo" (SySS). *News coverage of security research.*

65. Insurance Business, "Deepfake video conference sees criminals escape with US$25 million". *Secondary news coverage.*
66. NCC Group, Bluetooth Low Energy link-layer relay attack disclosure (May 2022). *Security research disclosure.*
67. TU Darmstadt SEEMOO, "Understanding the Apple Auto Unlock Protocol" (thesis, 2017). *Academic thesis page.*
68. Nevo et al., "Securing AI Model Weights" (RAND RR-A2849-1, 2024). *Think-tank report (PDF mirror of the RAND publication).*
69. The Block, "Crypto wrench attacks rise; victims' family members at risk" (CertiK, 2026). *News coverage of industry data.*
70. Jameson Lopp, "Wrench Attacks" talk transcript (Bitcoin 2025). *Conference talk (secondary).*
71. Chen et al., "FaceHeart" (IEEE INFOCOM 2017). *Peer-reviewed.*
72. VivoKey, Apex implant. *Vendor claim.*
73. Yeshiva University, "Attacking mmWave-enabled chest vibration sensing via actuator-induced mimicry". *University release on research.*
74. Microsoft Learn, "Windows Hello Enhanced Sign-in Security". *Vendor documentation.*
75. Apple Support, "About Optic ID advanced technology". *Vendor documentation (accuracy is a vendor claim).*
76. Dhar, Ulqinaku, Kostiainen, Capkun, "ProtectIOn: Root-of-Trust for IO in Compromised Platforms" (NDSS 2020). *Peer-reviewed.*
77. Venugopalan et al., "Electromyograph and keystroke dynamics for spoof-resistant biometric authentication" (CVPR Workshops 2015). *Peer-reviewed.*
78. National Research Council, "The Polygraph and Lie Detection" (2003). *National Academies report.*
79. Niinuma, Park, Jain, soft biometrics for continuous authentication (IEEE TIFS 2010), Sogang record. *Peer-reviewed (record page).*
80. Apple Platform Security, "System security for watchOS". *Vendor documentation.*
81. iRhythm, Zio monitor instructions for use. *Vendor instructions for use.*
82. Dexcom FAQ, "How long does the Dexcom G7 15 Day sensor last?". *Vendor documentation.*
83. IEEE Spectrum, "Biolinq's needle-free glucose monitor". *Trade press.*
84. EDITH: ECG biometrics aided by deep learning (arXiv 2102.08026). *Academic preprint.*
85. Casa documentation, "Inheritance". *Vendor documentation.*
86. Electronic Specifier, "Forget fingerprints, you can pay with your heartbeat" (original Nymi Band). *Trade press.*
87. Wareable, Nymi Band review. *Trade press review.*
88. TechXplore, Halifax ECG wearable identity trial (2015). *News coverage.*
89. Safety Mag, "Nymi workplace wearable wristband 3.0". *Trade press (vendor claims).*
90. Nymi, Nymi Band product page. *Vendor documentation.*
91. Thiebaud et al., "Learning Cardiac Features: ECG Biometrics Across Time and Exercise" (arXiv 2609.21962, Sept 2026). *Academic preprint (abstract read).*
92. "ECG biometric: spoofing and countermeasures" (IEEE T-BIOM 2020), SJSU ScholarWorks record. *Peer-reviewed (record page).*
93. FDA De Novo DEN180044 (Apple ECG app), via Innolitics. *Regulatory record.*
94. MD+DI, "iRhythm Zio monitor study holds promise for ECG wearable innovation". *Trade press (vendor-sponsored data).*
95. FDA 510(k) K190916 (VitalConnect VitalPatch), via Innolitics. *Regulatory record.*

96. "Know Me by My Pulse": wrist-PPG continuous authentication (NDSS 2026, arXiv 2508.13690). *Peer-reviewed (preprint version).*
97. PPGTransID, wearable PPG verified against facial rPPG (arXiv 2602.08972). *Academic preprint.*
98. TechCrunch, "Apple confirms tattoos can affect Apple Watch's heart-rate sensor readings" (2015). *News coverage (2015).*
99. US Patent 9,558,336, persistent authentication with on-body detection. *Patent.*
100. Kaifosh, Reardon et al., "A generic non-invasive neuromotor interface for human-computer interaction" (Nature 645, 2025), RePEc record. *Peer-reviewed (record page).*
101. PCWorld, "Meta's new Ray-Ban AI smart glasses are controlled using gestures". *Trade press.*
102. Deutsche Telekom, launch of Meta Ray-Ban Display (Oct 2026). *Vendor press release.*
103. Pradhan, He & Jiang, GRABMyo multi-day EMG dataset (Scientific Data, 2022). *Peer-reviewed.*
104. EMG gesture-code biometric authentication (Frontiers in Bioengineering and Biotechnology, 2020). *Peer-reviewed.*
105. Review of EMG biometrics (NSF PAR 10540505). *Peer-reviewed review.*
106. NEC, ear acoustic authentication press release (Mar 2016). *Vendor claim.*
107. NEC, Hearable Device global pre-sale (Oct 2022). *Vendor press release.*
108. University at Buffalo, EarEcho ear-canal authentication (Sept 2019). *University release on research.*
109. Apple Vision Pro User Guide, lock and wake behaviour. *Vendor documentation.*
110. CNET (via Yahoo Tech), Meta Ray-Ban Display hands-on. *Trade press.*
111. Route Fifty, "Businesses can't require microchip implants for workers under new Washington law" (Mar 2026). *News coverage.*
112. SHRM, "Another state bans employers from microchipping workers". *Professional association news.*
113. O'Connor et al., kinship analysis with additional STR loci (NIST/Promega proceedings, 2010). *Government scientific presentation.*
114. Huber et al., stability of infrared molecular fingerprints of blood (Nature Communications, 2021), RePEc record. *Peer-reviewed (record page).*
115. Herrero et al., CGM traces as a digital fingerprint (ATTD 2021 abstract). *Conference abstract (accuracy unverified).*
116. BioSpace, "Biolinq Shine granted De Novo classification by U.S. FDA" (Sept 2025). *Vendor press release.*
117. Dexcom FAQ, "Why does Dexcom G7 15 Day require a 60-minute warm-up?". *Vendor documentation.*
118. Isobornyl acrylate allergy in diabetes-device users (Acta Dermato-Venereologica, 2024). *Peer-reviewed.*
119. Microsoft Support, "Using third-party fingerprint readers and cameras with Windows Hello". *Vendor documentation.*
120. Tom's Guide, "Face ID for Mac is reportedly not coming for years" (Oct 2025). *Secondary (reporting of Bloomberg).*
121. US Patent 12,596,778, fingerprint sensing in typing keys. *Patent.*
122. Sim, Kumar et al., continuous verification with face and mouse fingerprint (ACSAC 2005 abstract). *Peer-reviewed (abstract).*
123. Fulcrum Biometrics, Fujitsu PalmSecure F Pro mouse listing. *Reseller listing.*
124. Mondal & Bours, keystroke-plus-mouse continuous authentication trust model, CPS-VO record. *Peer-reviewed (record page).*
125. Conditional-GAN presentation attack on keystroke dynamics (arXiv 2212.08445). *Academic preprint.*
126. Eberz et al., "Preventing Lunchtime Attacks: Fighting Insider Threats With Eye Movement Biometrics" (NDSS 2015). *Peer-reviewed.*

27. Eberz et al. (2017), systematic per-user errors in biometric evaluation, CPS-VO record. *Peer-reviewed (record page).*
28. Help Net Security, "Tobii Aware comes to MSI laptops" (Mar 2022). *Trade press (vendor claims).*
29. Martinez et al., BeatFormer supplementary material (ICCV 2025 Workshops). *Peer-reviewed (supplement).*
30. GVT2RPM cross-dataset rPPG evaluation (arXiv 2406.13136). *Academic preprint.*
31. MMPD: multi-domain mobile video physiology dataset (EMBC 2023, arXiv 2302.03840). *Peer-reviewed (preprint version).*
32. PetaPixel, "Deepfake detection software analyzes a person's blood flow" (Intel FakeCatcher). *Trade press (vendor claim).*
33. Reclaim The Net, summary of a BBC test of FakeCatcher (July 2023). *Secondary coverage.*
34. Google Research, "Contactless sleep sensing in Nest Hub". *Vendor research blog.*
35. Infineon, radar presence detection. *Vendor claim.*
36. TI E2E forum, IWR6843 vital-signs measurement conditions. *User forum material.*
37. University at Buffalo, Cardiac Scan radar authentication (MobiCom 2017). *University release on research.*
38. Rodriguez, Wang, Li, spoofing radar cardio-respiratory authentication (IEEE RWS 2021), CPS-VO record. *Peer-reviewed (record page).*
39. Lenovo ThinkPad 13s user guide, "User Presence Sensing". *Vendor documentation.*
40. Apple Platform Security, "Face ID, Touch ID, passcodes, and passwords". *Vendor documentation (accuracy figures are vendor claims).*
41. The Register, "Windows Hello fingerprint authentication bypassed" (Blackwing Intelligence, Nov 2023). *News coverage of security research (patched).*
42. Slickdeals, Aqara Presence Sensor FP2 deal listing (Jan 2026). *Retail deal listing.*
43. Pew Research Center, "About one-in-five Americans use a smart watch or fitness tracker" (2020). *Survey research.*
44. Computerworld, "Smartwatch user dropout rate is still 29%, Gartner says". *Trade press reporting analyst survey.*
45. Apple Newsroom, "Apple debuts Apple Watch Series 11" (Sept 2025). *Vendor claim.*
46. Android Authority, Meta Ray-Ban Display and Neural Band. *Trade press (vendor figures).*
47. IEEE Spectrum, "Latest tests of biometrics systems show wide range of abilities". *Trade press.*
48. Operational study of fingerprint quality in older people (arXiv 2409.19992). *Academic preprint.*
49. Scottish Health Technologies Group, ECG patch monitors advice. *Government health technology assessment.*
50. Rostami, Juels, Koushanfar, "Heart-to-Heart (H2H)" (ACM CCS 2013). *Peer-reviewed.*
51. Lin et al., "H2B: heartbeat-based secret key generation" (IPSN 2019, arXiv 1904.00750). *Peer-reviewed (preprint version).*
52. Latent-space editing of physiological signals in face video (arXiv 2509.25348). *Academic preprint.*
53. Seepers et al., remote PPG as a threat to heartbeat-based security (IEEE JBHI), Chalmers record. *Peer-reviewed (record page).*
54. Mare et al., "ZEBRA: Zero-Effort Bilateral Recurring Authentication" (IEEE S&P 2014). *Peer-reviewed.*
55. Acar et al., "WACA: Wearable-Assisted Continuous Authentication" (arXiv 1802.10417). *Academic preprint (author claims).*
56. VoxAnchor: speech-synchronized vibration authentication (arXiv 2603.27562). *Academic preprint.*
57. Gazzari et al., "My(o) Armband Leaks Passwords" (arXiv 2112.02382). *Academic preprint.*
58. Google Research, smartwatch motion-sensor keystroke inference (pub44642). *Peer-reviewed (publication page).*
59. Microsoft Learn, SendInput function. *Vendor documentation.*

60. Microsoft Learn, "Microsoft Pluton security processor". *Vendor documentation.*
61. USB-IF, USB Authentication Specification Rev 1.0 (document library). *Industry specification.*
62. McCune, Perrig, Reiter, "Safe Passage for Passwords and Other Sensitive Data" (Bumpy, NDSS 2009). *Peer-reviewed.*
63. Libonati, McCune, Reiter, usability study of trusted-path input (NDSS). *Peer-reviewed.*
64. Eskandarian et al., "Fidelius: Protecting User Secrets from Compromised Browsers" (IEEE S&P 2019, arXiv 1809.04774). *Peer-reviewed (preprint version).*
65. Mare et al., "CSAW: continuous smartphone authentication using wristbands" (2019). *Peer-reviewed.*
66. Cloudflare Turnstile documentation. *Vendor documentation.*
67. Cloudflare blog, "Eliminating CAPTCHAs on iPhones and Macs using new standard" (Private Access Tokens). *Vendor documentation (claims).*
68. IETF RFC 9576, "The Privacy Pass Architecture". *Standards document.*
69. TechCrunch, "World launches tool to verify humans behind AI shopping agents" (Mar 2026). *News coverage.*
70. Adler, Hitzig, Jain et al., "Personhood credentials" (arXiv 2408.07892). *Academic preprint.*
71. Windows Experience Blog, "Securing AI agents on Windows" (Oct 2025). *Vendor announcement.*
72. IETF Datatracker, draft-oauth-ai-agents-on-behalf-of-user (expired Feb 2026). *Individual Internet-Draft.*
73. Visa, "Visa introduces Trusted Agent Protocol" (Oct 2025). *Vendor press release.*
74. IETF Datatracker, draft-ietf-webbotauth-httpsig-protocol (Sept 2026). *Working-group draft.*
75. Business Wire, Mastercard Agent Pay announcement (Apr 2025). *Vendor press release.*
76. NIST, "New concept paper on identity and authority of software agents" (Feb 2026). *Government announcement.*
77. Decentralized Identity Foundation, "KYA-OS". *Standards-body blog.*
78. Claude Platform documentation, "Computer use tool". *Vendor documentation.*
79. US Patent 7,287,013, biometric fusion. *Patent.*
80. Altinok & Turk, "Temporal integration for continuous multimodal biometrics" (2003). *Peer-reviewed.*
81. Deutschmann & Lindholm, continuous authentication with behavioral biometrics (BIOSIG 2013). *Peer-reviewed.*
82. Khan, Hengartner, Vogel, implicit authentication usability (SOUPS 2015). *Peer-reviewed.*
83. VIGIL: three-zone continuous authentication decisions (arXiv 2607.16651). *Academic preprint (self-reported results).*
84. Apple Platform Security, "Uses for Optic ID, Face ID, and Touch ID". *Vendor documentation.*
85. Android Authority, Apple Watch Series 11, Ultra 3 and SE 3 launch. *Trade press (secondary).*
86. heise online, Apple Watch SE 3 specifications. *Trade press (secondary).*
87. MedTech Dive, Withings ScanWatch FDA clearance and US launch. *Trade press.*
88. Android Authority, "Oura Ring 4 vs Samsung Galaxy Ring". *Trade press (secondary).*
89. Oura, membership pricing. *Vendor pricing.*
90. Cornell Store, Apple Magic Keyboard with Touch ID and Numeric Keypad listing. *Reseller listing.*
91. MedTech Dive, "Dexcom sells Stelo over-the-counter CGM". *Trade press.*
92. MedTech Dive, "Abbott Lingo rollout as US OTC CGM". *Trade press.*
93. NVIDIA Attestation documentation, Hopper single-GPU example. *Vendor documentation.*

194. NVIDIA blog, "Azure confidential VMs with NVIDIA H100 generally available" (Sept 2024). *Vendor announcement.*

195. Fortanix, "Fortanix Confidential AI protects proprietary model IP" (Mar 2026). *Vendor press release.*

196. NIST FIPS 140-2, Security Requirements for Cryptographic Modules. *Government standard (level definitions carried into FIPS 140-3).*

197. TEE.fail project site (IEEE S&P 2026; disclosed Oct 2025). *Academic research disclosure.*

198. US Air Force Instruction 91-104, Nuclear Surety Tamper Control and Detection Programs. *Government instruction (PDF mirror).*

199. SL5 Task Force, "Releasing the SL5 Standard v0.1" (Mar 2026). *Nonprofit draft standard (public summary).*

200. FitGap, Nymi listing (starter kit pricing). *Third-party listing.*

201. Fulcrum Biometrics, Fujitsu PalmSecure F Pro sensor listing. *Reseller listing (price).*

202. Toshnazarov et al., SOSW smartwatch stress detection (KAIST, 2024). *Peer-reviewed (lab and field).*

203. Axelsson, "The Base-Rate Fallacy and the Difficulty of Intrusion Detection" (ACM TISSEC, 2000). *Peer-reviewed.*

204. FingerTec training material, duress finger feature. *Vendor documentation.*

205. FTC Bureau of Economics, staff report on emergency technology at ATMs (2010). *Government report.*

206. Czeskis, Kohno, Schneier et al., "Defeating Encrypted and Deniable File Systems" (USENIX HotSec 2008). *Peer-reviewed.*

207. GrapheneOS, Features overview (duress PIN/password). *Project documentation.*

208. CTV News Toronto, "Special safes led to a dramatic drop in pharmacy robberies in Toronto: police". *News coverage of police data (uncontrolled before/after).*

209. Möser, Eyal, Sirer, "Bitcoin Covenants" (2016). *Peer-reviewed.*

210. NDSS 2024 paper on honeywords. *Peer-reviewed.*

211. Houses of the Oireachtas, written answer on tiger kidnappings (10 Nov 2009). *Parliamentary record (partially verified).*

212. 1Password blog, "Introducing Travel Mode" (2017). *Vendor documentation.*

213. Vitalik Buterin, "Why we need wide adoption of social recovery wallets" (2021). *Design essay.*

214. Bitwarden Help, "Emergency Access". *Vendor documentation.*

215. EDPB Opinion 11/2024 on facial recognition to streamline airport passenger flows. *Regulator opinion.*

216. BitBox blog, "Exploring Bitcoin miniscript with Liana and the BitBox02". *Vendor blog.*

217. BIP 112, OP_CHECKSEQUENCEVERIFY. *Protocol specification.*

218. US EEOC, Fact sheet on the Genetic Information Nondiscrimination Act. *Government guidance.*

219. Regulation (EU) 2016/679, General Data Protection Regulation (EUR-Lex). *EU law.*

220. IANA, Root KSK Ceremony 13. *Primary ceremony record.*

221. AWS CloudHSM User Guide, "Quorum authentication". *Vendor documentation.*

222. Google Account Help, "About Inactive Account Manager". *Vendor documentation.*

223. SatoshiLabs, SLIP-0039: Shamir's Secret-Sharing for Mnemonic Codes. *Specification.*

224. Microsoft Learn, "Manage emergency access accounts in Microsoft Entra ID". *Vendor documentation.*

225. Davis Wright Tremaine, "Illinois BIPA biometrics law amended for damages" (Aug 2024). *Law-firm summary.*

226. Paul Hastings, "7th Circuit confirms BIPA amendment has retroactive application" (Clay v. Union Pacific, Apr 2026). *Law-firm summary.*

227. UB Greensfelder, "Illinois federal court rules Apple may be in possession of biometric data stored on user devices" (Hazlitt v. Apple). *Law-firm summary.*

228. Hazlitt v. Apple, S.D. Ill., class certification order, Doc. 342 (June 5, 2026), via CourtListener. *Court record.*

229. BetaNews, "Apple $32.5 billion BIPA lawsuit". *Secondary news coverage.*

230. Duane Morris Class Action Defense Blog on Barnett v. Apple (Ill. App. Ct., 2022). *Law-firm case summary.*

231. Washington Attorney General, "Protecting Washingtonians' personal health data and privacy". *Government guidance.*

232. WilmerHale, "First lawsuit filed under Washington's My Health My Data Act" (Feb 2025). *Law-firm summary.*

233. Lan & Yeo, keystroke hold-time index for early Parkinson's (PLOS One 2019), PMC. *Peer-reviewed.*

234. Hunton, "Connecticut and Nevada legislatures pass health data laws". *Law-firm summary.*

235. Texas Attorney General, "$1.4 billion settlement with Meta over unauthorized capture of biometric data" (July 2024). *Government press release.*

236. Cybersecurity Law Report, Texas AG billion-dollar settlement with Google. *Legal trade press (secondary).*

237. Mayer Brown, "FTC issues policy statement on biometric information" (May 2023). *Law-firm summary.*

238. Fierce Healthcare, "Rite Aid's reckless use of AI facial recognition tech earns 5-year ban from FTC". *News coverage of enforcement.*

239. FTC, Health Breach Notification Rule final amendments (Apr 2024). *Government rule announcement.*

240. White & Case, "Unpacking the FTC's COPPA amendments" (2025). *Law-firm summary.*

241. EU AI Act Recital 17 (EC AI Act Service Desk). *EU law.*

242. Irish Data Protection Commission, "What is the household exemption?". *Regulator guidance.*

243. Dahi & Compagnucci, on device manufacturers as controllers for edge processing. *Academic commentary.*

244. EU AI Act Article 50 (EC AI Act Service Desk, consolidated text). *EU law.*

245. Gibson Dunn, "EU AI Act omnibus agreement: postponed high-risk deadlines and other key changes". *Law-firm summary.*

246. Regulation (EU) 2024/1689, Artificial Intelligence Act (EUR-Lex). *EU law.*

247. Garrigues, "AI Digital Omnibus Regulation has been published" (2026). *Law-firm summary.*

248. AI Act Annex III (artificialintelligenceact.eu). *EU law (unofficial reproduction).*

249. Article 29 Working Party, Guidelines on consent (WP259). *Regulator guidance (PDF mirror).*

250. AKD, "The Dutch GDPR implementation act and the use of biometric data". *Law-firm summary.*

251. IAPP, "Dutch DPA issues record 725K euro fine for GDPR violations" (2020). *Trade press.*

252. PwC Legal Belgium, Belgian DPA fines employer EUR 45,000 (2024). *Law-firm summary.*

253. CNIL, "La biométrie sur les lieux de travail" (model regulation 2019-001). *Regulator guidance.*

254. EDPB-EDPS Joint Opinion 2/2026 on the Digital Omnibus. *Regulator opinion.*

255. Littler, "Implications for employers of Colorado's new biometrics law" (HB24-1130). *Law-firm summary.*

256. Revised Code of Washington 19.375.020, Biometric identifiers. *Statute.*

257. New York Labor Law § 201-a. *Statute.*

258. White & Case, "CPPA finalizes rules on ADMT, risk assessments and cybersecurity audits" (2025). *Law-firm summary.*

259. Holland & Knight, "New York law requires notice of employees' electronic monitoring" (2022). *Law-firm summary.*

260. Wolters Kluwer Global Workplace Law & Policy, "Everywhere at once: the Digital Omnibus and the missing protection for workers". *Legal commentary.*

261. Harvard Law School Forum on Corporate Governance, "Executive security and protection continues to expand" (Sept 2026). *Practitioner analysis of proxy data.*

262. BNN Bloomberg, "Electronic device searches by US border officials are on the rise" (Aug 2025). *Secondary news coverage.*

263. Casa, pricing. *Vendor pricing.*

264. Capterra, BlackCloak listing. *Third-party listing.*

265. Purism, Liberty Phone pricing. *Vendor pricing.*

266. Breaker, "Sirin Labs lays off staff as blockchain phone sells poorly" (2019). *Secondary news coverage.*

267. Android Authority, "Android 16 inactivity reboot". *Trade press (secondary).*

268. Cloud Security Alliance, research note on CAISI frontier AI testing agreements (2026). *Industry research note (secondary).*

269. Mayer Brown, "California enacts SB 53" (Oct 2025). *Law-firm summary.*

270. Wiley, "New York finalizes RAISE Act for frontier AI models; law takes effect January 1, 2027". *Law-firm summary.*

271. EU GPAI Code of Practice, Safety & Security chapter (final, July 2025), via code-of-practice.ai. *Unofficial mirror of the final text.*

272. TechCrunch, "Irregular raises $80 million to secure frontier AI models" (Sept 2025). *News coverage.*

273. Teleport documentation, access controls guides. *Vendor documentation.*

274. CyberArk, fourth-quarter and full-year 2025 results. *Company financial release.*

275. SDxCentral, "Palo Alto Networks completes $25B CyberArk deal". *Trade press.*

276. Okta Help, "Identity Threat Protection overview". *Vendor documentation.*

277. Yubico, "HYPR and Yubico". *Vendor documentation.*

278. OpenID Foundation, "Identity Management for Agentic AI" whitepaper (Oct 2025). *Industry body.*

279. Meta, facebookresearch/generic-neuromotor-interface dataset and code. *Public research dataset.*

---

Vault · architecture research v2 · October 2026. v2 replaces the gate-based design of v1 (PDF) with an always-on verification loop and adds the consumer tier. This research is not legal advice; regulatory readings are flagged as interpretation where the sources leave them open.